360 ADVANCED

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

# HIPAA Security Compliance Assessment for AI Services

## Anthropic, Inc.

*September 30, 2024*

Confidential Information: This document contains confidential information and is the property of Anthropic, Inc. and 360 Advanced, Inc. If you are not an authorized recipient, please return this document to the owners. Dissemination, distribution, copying or use of this document in whole or in part by unauthorized recipients is strictly prohibited.

# ANTHROPIC, INC.

## Table of Contents

**SECTION 1: EXECUTIVE SUMMARY** ..... **1**

**SECTION 2: MANAGEMENT'S ASSERTION** ..... **3**

**SECTION 3: SCOPE, OBJECTIVES, AND COMPANY OVERVIEW** ..... **5**

Overview of the AI Services ..... 6

**SECTION 4: METHODOLOGY** ..... **7**

OVERVIEW ..... 8
Procedures Performed ..... 8
Assumptions ..... 8
Constraints ..... 8

**SECTION 5: COMPLIANCE ABSTRACT** ..... **9**

Regulatory Compliance ..... 10
Security and Privacy ..... 10
Electronic Protected Health Information ..... 10
Protected Health Information ..... 11

HIPAA – Health Insurance Portability and Accountability Act ..... 11
The Privacy Rule ..... 13
The Security Rule ..... 13
HIPAA Security Rule Illustration ..... 14
Administrative Safeguards ..... 14
Physical Safeguards ..... 15
Technical Safeguards ..... 15

Approach to Addressability for this Assessment ..... 16

**SECTION 6: CONTROL DESCRIPTIONS AND TEST OF CONTROLS** ..... **17**

INFORMATION PROVIDED BY THE ASSESSOR ..... 18
Introduction ..... 18
Types of Tests Performed ..... 19

Testing Matrices ..... 20
§164.308 Administrative Safeguards ..... 20
§164.310 Physical Safeguards ..... 52
§164.312 Technical Safeguards ..... 55
§164.314 Organizational Requirements ..... 64
§164.316 Policies, Procedures and Documentation Requirements ..... 67

**SECTION 7: INFORMATION PROVIDED BY THE SERVICE ORGANIZATION THAT IS NOT COVERED BY THE SERVICE AUDITOR'S REPORT** ..... **75**

Management's Responses to the Testing Exceptions ..... 76

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by ssag@cloudcontrolstudio.com

## SECTION 1:

## EXECUTIVE SUMMARY

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

## EXECUTIVE SUMMARY

360 Advanced, Inc. ("360 Advanced") is pleased to submit this Health Insurance Portability and Accountability Act (HIPAA) Security Compliance Assessment Report for Anthropic, Inc. ("Anthropic"). The services performed were an assessment of internal controls in place to satisfy the Omnibus Final Security Rule governing "protected health information" that the Department of Health and Human Services issued in January 2013. This compliance assessment involved understanding the AI Services provided by Anthropic, and documenting and verifying the safeguards in place to meet the relevant aspects of the Omnibus final rule on behalf of covered entities who maintain health information within Anthropic's software and cloud environments.

This security compliance assessment included an analysis of the information technology (IT) processes and infrastructure, controls, policies, and procedures that affect the confidentiality, integrity, and availability of the information technology systems and data as they relate to Anthropic's AI Services. In some cases, the HIPAA Rule did not apply to the services provided by Anthropic and is noted as Not Applicable (N/A) in Section 6 (Testing Matrices) of this report.

Through a data collection process, review of pertinent security-related documentation, interviews with key personnel, walk-throughs of processes and procedures, and tests of controls, where applicable, the 360 Advanced assessors compiled the necessary data for the analysis and review. The results of the compliance assessment are detailed in Section 6 (Testing Matrices) and should be reviewed and interpreted by each covered entity to determine if the safeguards in place are sufficient to meet their unique HIPAA compliance needs.

Specifically, our procedures addressed each specification in the HIPAA Security Final Rule. The procedures applied were used to gain an understanding of the environment as it relates to the HIPAA Security Final Rule and to provide an independent assessment of the controls in place. Our review was not intended to provide an opinion regarding the design or operating effectiveness of the controls identified during this assessment. Rather, to present in an independent fashion the documented and verified controls in place at Anthropic that relate to each HIPAA Security Final Rule requirement.

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asaad@cloudcontrolstudio.com

## SECTION 2:

## MANAGEMENT'S ASSERTION

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

# MANAGEMENT OF ANTHROPIC, INC.'S ASSERTION

February 10, 2025

We have prepared the description of Anthropic, Inc.'s ("Anthropic") AI Services for users of the services as of September 30, 2024 who have a sufficient understanding to consider the services, along with other information, including information about the controls implemented by Anthropic that address the HIPAA Security Final Rule regarding user entities' ePHI data. We confirm, to the best of our knowledge and belief, the following:

a. The description fairly presents the AI Services made available to users of the services as of September 30, 2024 . The criteria we used in making this assertion were that the description

   i. presents how the processes, procedures and controls that support the services provided to users were designed and implemented to address the applicable safeguards defined within the HIPAA / HITECH Security Rule as they relate to our environment, including when applicable:

      1. the types of services provided;
      2. the procedures, within both automated and manual systems, by which services are provided; and
      3. the control activities performed that address the applicable HIPAA Security Final Rule;

   ii. does not omit or distort information relevant to the scope of the AI Services, while acknowledging that the description is presented to meet the common needs of a broad range of users of the system, and may not, therefore, include every aspect of the AI Services that each individual user of the services may consider important in its own particular environment.

b. The controls related to each HIPAA Security Final Rule stated in the description were suitably designed and placed in operation as of September 30, 2024 to satisfy the Security Final Rule. The criteria we used in making this assertion were that

   i. the controls identified that address each HIPAA Security Final Rule stated in the description have been identified by management; and

   ii. the controls were consistently applied as designed, including whether manual controls were applied by individuals who have the appropriate competence and authority.

/s/ Anthropic, Inc.

Jason Clinton – Chief Information Security Officer

Larkin Ryder – Head of Compliance

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by aegis@cloudcontrolstudio.com

## SECTION 3:

## SCOPE, OBJECTIVES, AND COMPANY OVERVIEW

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

## SCOPE AND OBJECTIVES

The HIPAA Security Compliance Assessment addressed Administrative, Physical, and Technical Safeguards, with primary focus on the Security Final Rule as they relate to Anthropic's AI Services. More specifically:

- **Administrative Safeguards** security includes the overall security management process; assigned security responsibility, workforce security, information access management, security awareness and training, security incident procedures, contingency planning, evaluation, and business associate contracts or other arrangements;
- **Physical Safeguards** security includes facility access controls, workstation use, workstation security, as well as portable devices and media controls;
- **Technical Safeguards** security includes audit controls, integrity, personnel or entity authentication, and transmission security;
- **Organizational Requirements** implement BAA contracts that comply with the security measures; and
- **Policies, Procedures and Documentation Requirements** implement reasonable and appropriate policies and procedures to comply with standards, implementation specifications, or other requirements.

## COMPANY OVERVIEW AND DESCRIPTION OF SERVICES

Anthropic is an artificial intelligence (AI) company and public-benefit corporation, founded in 2021. Anthropic specializes in developing general AI systems and language models, with a company ethos of responsible AI usage. The company was created with the goal of building beneficial artificial intelligence aligned with human values and priorities. Anthropic uses a technique called Constitutional AI to train language models via natural language feedback to be helpful, harmless, and honest. The company translates their research into tangible, practical tools, to benefit businesses, nonprofits, civil society groups, as well as people around the globe.

## Overview of the AI Services

Anthropic provides an Application Programming Interface (API) that can be integrated into customer applications or cloud environments via the Anthropic API service. The Anthropic Console is available for clients to access and manage their API keys. Users interact with the API via the POST method and authenticate using secret API keys. The POST method is designed to send loads of data to a server from a specified resource.

Anthropic processes AI assistant and API calls using its cloud-hosted machine learning (ML) inference infrastructure and returns the generated response in a streaming manner via Server-Sent Events (SSE). Console prompts and responses are sent over hypertext transfer protocol secure (HTTPS) / transport layer security (TLS). Users of the Console are authenticated using OAuth, which means that no user login credentials are stored on Anthropic's end.

Alternatively, customers may use API-based access to Anthropic's models hosted within their own trust boundary on Google Vertex or Amazon Bedrock. Users of Google Vertex and Amazon Bedrock are authenticated using the cloud service providers' (CSPs) identity and access management (IAM) systems under the customer's control. Notably, Anthropic is unable to access prompts or responses sent via these services.

Downloaded at Fri, 11 Apr 2025 15:10:36 GMT
Downloaded by asaad@cloudcontrolstudio.com

## SECTION 4:

## METHODOLOGY

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

## OVERVIEW

The methodology employed in conducting this HIPAA Security Compliance Assessment applied a structured approach to identify and evaluate the controls in place associated with the operations of the IT environment and the business operations environment.

### Procedures Performed

360 Advanced assembled a team to perform the data collection and analysis for this project. Data collection and analysis for this project employed the following four distinct methods:

1. **Reviewing pertinent documentation –** 360 Advanced requested and received numerous documents relevant to IT security, enterprise networks, and business operations at Anthropic. The information extracted from these documents was critical to the analysis of Anthropic's IT security and business operations posture;

2. **Interviewing key personnel –** 360 Advanced collected technical security and business process information through technical interviews. Interviews were conducted with key staff members and executive management, which further served to identify operational facets of Anthropic's security program. These interviews gathered information to ascertain existing security risks and controls for each identified component. These procedures involved inquiries of the following key personnel:
    - Siah Burke, HIPAA Security Officer
    - Stephen Jung, Infrastructure Engineer
    - Jackie Bow, Detection and Response Security Engineer
    - Matt McNiece, Security Engineer

3. **Test of controls –** 360 Advanced performed tests of controls, including sample testing, where applicable, to verify the controls were in place and operating as designed.

### Assumptions

Information provided to the 360 Advanced assessors was presumed to be accurate unless the interviewee indicated uncertainty in their answer in which case that is noted in the report.

### Constraints

This report scope was limited to the information technology enterprise and Anthropic 's operations at their AWS and GCP cloud environments, as they existed as of September 30, 2024.

The threats, risks, vulnerabilities, and controls discussed in this report pertain to the previously identified location as they existed during the previously specified period of time. Changes made to the environment subsequent to the date of this report may or may not be accurately reflected in this report.

No Anthropic offices and customer sites were visited, and no customer information technology resources were assessed during the course of this assessment.

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

## SECTION 5:

## COMPLIANCE ABSTRACT

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

## Regulatory Compliance

In general, compliance means conforming to a specification or policy, standard or law that has been clearly defined. There are a wide variety of these, including state laws which are often more stringent and preempt federal regulations, and Anthropic must work to ensure that they are aware of and will or have taken steps to comply with applicable laws and regulations.

Within the context of this project, the assessment scope was predetermined to have a particular focus on compliance with the Omnibus Final Rule.

## Security and Privacy

Security and Privacy are interlocking. Privacy is not possible unless Security is in place to protect the asset that is considered private. Without security, privacy is at risk. Controls are established to mitigate risk, sometimes lessening the prospect for threat materialization and eventual vulnerability exploit.

The most basic definition of privacy is the confidential safekeeping of information that would not be reasonably available to others unless 'they' had explicit access permission or met other specific access requirements. Complexity begins with defining which information needs protection, as private, sensitive, or protected information, as these can mean something different to everyone based on personal values, cultural norms, business context, and many other factors. For this reason, Anthropic's policies and supporting training in the handling of private information must be explicit and conveyed frequently and done so in a manner that validates individual understanding of this topic.

Of specific concern is information in aggregate, or data "enriched" with other data sources to create a more valuable information set. Legal requirements for data protection tend to be less intuition-based than what one expects; however, the privacy compliance landscape by itself is by no means simple. The majority of states now have enacted data protection laws, many of which contain different requirements and definitions of covered data. When Anthropic handles data, it needs to know with a high-level of precision exactly what is required to comply with privacy and security, even to the extent of knowing what the requirements are of other states if working in or with them, or handling data in or through them, ensuring the handling of information meets privacy and security handling as well as notification requirements.

## Electronic Protected Health Information

In general, patient health information that has been converted to, stored in, or transmitted by electronic media is deemed to be "ePHI" and as such is to be controlled and protected under the HIPAA Privacy and Security Rules.

The following are examples of technology used to convert PHI to ePHI:

- Personal Computers with their internal hard drives used at work, home, or traveling;
- External portable hard drives, including iPods;
- Magnetic tape or disks;
- Removable storage devices such as USB memory sticks / keys, CDs, DVDs, and floppy diskettes;
- PDA's, smartphones; and
- Electronic transmission includes data exchange (e.g., email or file transfer) via wireless, ethernet, modem, DSL or cable network connections.
- As technology progresses, any new devices for accessing, transmitting, or receiving ePHI electronically will be covered by the HIPAA Security Rule.

Downloaded by [illegible] on 2025-05-15 15:56:36 GMT
Downloaded by [illegible] | hipaacontrolstudio.com

## Protected Health Information

PHI is defined under HIPAA, as any information about health status, provision of health care, or payment for health care that can be linked to an individual. This is interpreted rather broadly and includes any part of a patient's medical record or payment history. The following types of information are considered to be PHI:

1. Names;
2. All geographical subdivisions smaller than a State, including street address, city, county, precinct, zip code, and their equivalent geocode, except for the initial three digits of a zip code, if according to the current publicly available data from the Bureau of the Census: (1) The geographic unit formed by combining all zip codes with the same three initial digits contains more than 20,000 people; and (2) The initial three digits of a zip code for all such geographic units containing 20,000 or fewer people is changed to 000;
3. Dates (except year) for dates directly related to an individual, including birth date, admission date, discharge date, date of death; and all ages over 89 and all elements of dates (including year) indicative of such age, except that such ages and elements may be aggregated into a single category of age 90 or older;
4. Phone numbers;
5. Fax numbers;
6. Electronic mail addresses;
7. Social Security numbers;
8. Medical record numbers;
9. Health plan beneficiary numbers;
10. Account numbers;
11. Certificate and license numbers;
12. Vehicle identifiers and serial numbers, including license plate numbers;
13. Device identifiers and serial numbers;
14. Related (personal) Web Universal Resource Locators (URLs);
15. Internet Protocol (IP) address numbers;
16. Biometric identifiers, including finger and voice prints as well as DNA;
17. Full face photographic images and any comparable images; and
18. Any other unique identifying number, characteristic, or code (note this does not mean the unique code assigned by the investigator to code the data).

The handling of PHI within Anthropic must follow HIPAA requirements and must be stringently adhered to for compliance purposes. It should be noted that ePHI, the electronic form of PHI, is more difficult to manage than the printed copy form of this protected information.

## HIPAA – Health Insurance Portability and Accountability Act

The HIPAA Administration Simplification provisions address the *security and privacy* of health data. The standards are meant to improve the efficiency and effectiveness of the nation's health care system by encouraging the widespread use of electronic data interchange in the U.S. health care system.

The HIPAA regulations apply to "covered entities" and "business associates" as defined by HIPAA. **Covered entities** include health plans, health care clearinghouses (such as billing services and community health information systems), and health care providers that engage in electronic "standard transactions" that are regulated by HIPAA. A **Business associate** is a person or entity, other than a member of the workforce of a covered entity, who performs functions or activities on behalf of, or provides certain services

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

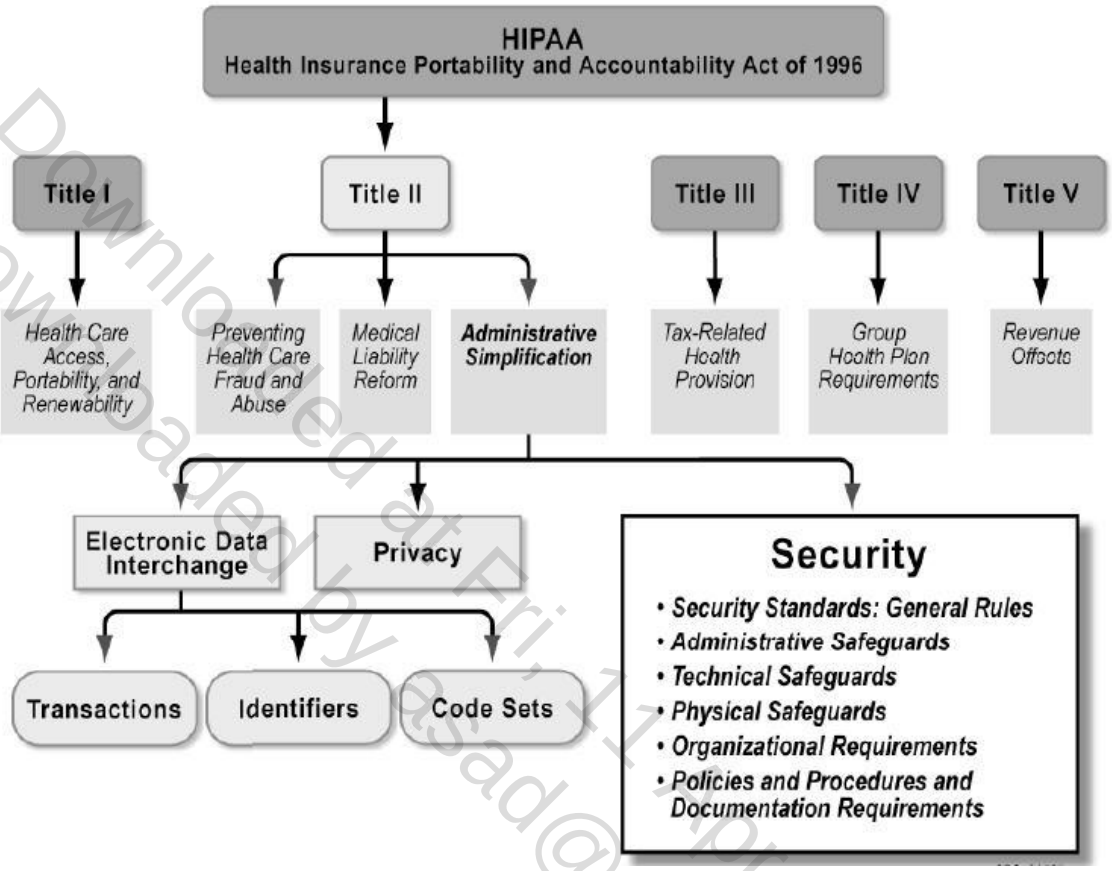
to, a covered entity that involves access by the business associate to protected health information. A business associate also is a sub-contractor that creates, receives, maintains, or transmits protected health information on behalf of another business associate. The HIPAA Rules generally require that covered entities and business associates enter into contracts with their business associates to ensure that the business associates will appropriately safeguard protected health information. The business associate contract also serves to clarify and limit, as appropriate, the permissible uses and disclosures of protected health information by the business associate, based on the relationship between the parties and the activities or services being performed by the business associate. A business associate is directly liable under the HIPAA rules and subject to civil and, in some cases, criminal penalties for making uses and disclosures of protected health information that are not authorized by its contract or required by law. A business associate also is directly liable and subject to civil penalties for failing to safeguard ePHI in accordance with the HIPAA Security Rule.

A written contract between a covered entity and a business associate must: (1) establish the permitted and required uses and disclosures of protected health information by the business associate; (2) provide that the business associate will not use or further disclose the information other than as permitted or required by the contract or as required by law; (3) require the business associate to implement appropriate safeguards to prevent unauthorized use or disclosure of the information, including implementing requirements of the HIPAA Security Rule with regard to electronic protected health information; (4) require the business associate to report to the covered entity any use or disclosure of the information not provided for by its contract, including incidents that constitute breaches of unsecured protected health information; (5) require the business associate to disclose protected health information as specified in its contract to satisfy a covered entity's obligation with respect to individuals' requests for copies of their protected health information, as well as make available protected health information for amendments (and incorporate any amendments, if required) and accountings; (6) to the extent the business associate is to carry out a covered entity's obligation under the Privacy Rule, require the business associate to comply with the requirements applicable to the obligation; (7) require the business associate to make available to HHS its internal practices, books, and records relating to the use and disclosure of protected health information received from, or created or received by the business associate on behalf of, the covered entity for purposes of HHS determining the covered entity's compliance with the HIPAA Privacy Rule; (8) at termination of the contract, if feasible, require the business associate to return or destroy all protected health information received from, or created or received by the business associate on behalf of, the covered entity; (9) require the business associate to ensure that any subcontractors it may engage on its behalf that will have access to protected health information agree to the same restrictions and conditions that apply to the business associate with respect to such information; and (10) authorize termination of the contract by the covered entity if the business associate violates a material term of the contract. Contracts between business associates and business associates that are subcontractors are subject to these same requirements.

Anthropic may provide its customers technical support and it is possible Anthropic personnel would have access to said customer's data which may consist of electronic protected health information. As such, under the HIPAA Final Rule, Anthropic is considered a business associate.

The figure below illustrates the structure of the HIPAA regulations. Note that the focus of this section is centered on the Security Rule requirements. The requirements for covered entities outlined on the following pages apply equally to Anthropic as a business associate.

Downloaded by [redacted] on 2025-11-15 16:36 GMT
Downloaded by [redacted] on 2025-11-15 16:36 GMT
Downloaded by [redacted] on 2025-11-15 16:36 GMT




Downloaded at Fri, 11 Apr 2025 06:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

### The Privacy Rule

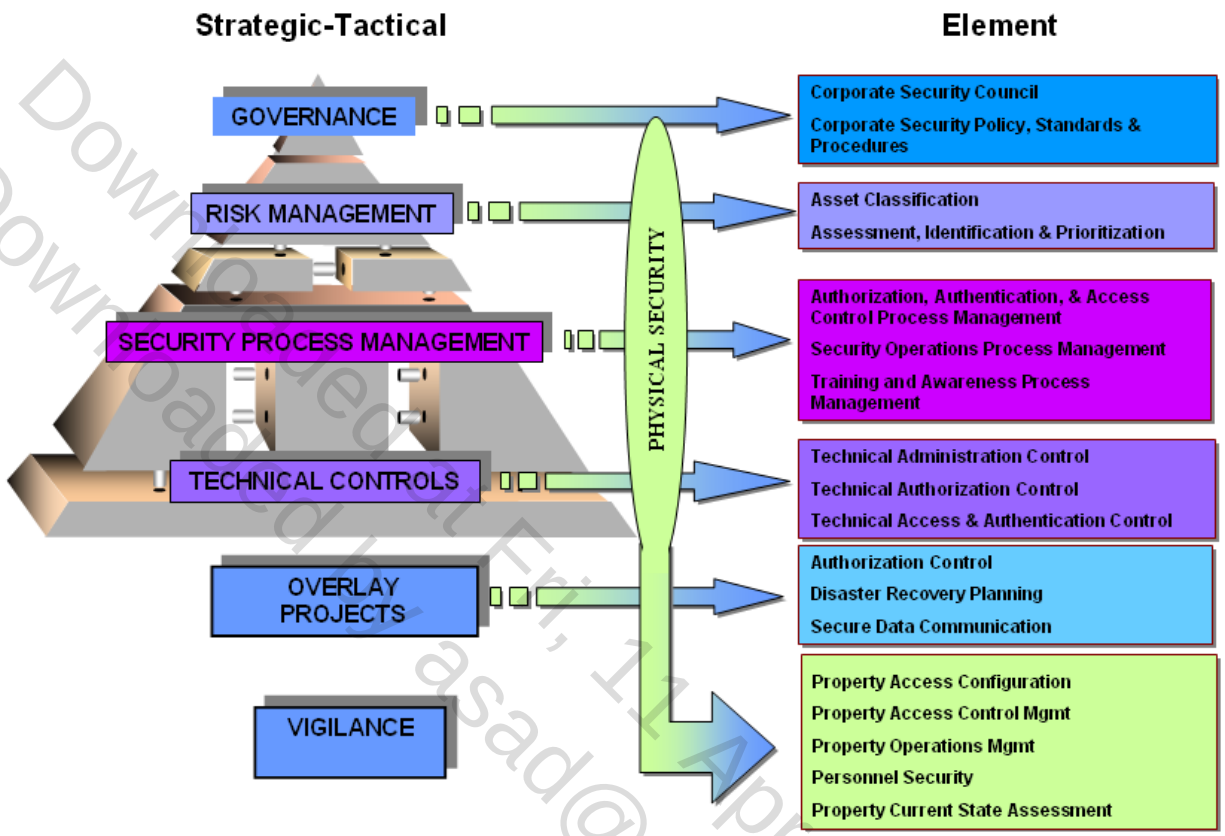
The Privacy Rule establishes regulations for the use and disclosure of Protected Health Information (PHI). PHI is discussed in this report and definitions are provided. Broadly interpreted, PHI includes any part of a patient's medical record or information regarding payment for health care. Because this report discusses Security Rule compliance, it does not analyze the requirements or compliance with the HIPAA Privacy Rule.

### The Security Rule

The Security Rule complements the Privacy Rule. While the Privacy Rule pertains to all PHI including paper and electronic, the Security Rule deals specifically with ePHI.

The Security Rule specifies three types of security safeguards required for compliance: administrative, physical, and technical. For each of these types, the Rule identifies various security standards, and for each standard, it names both required **[R]** and addressable **[A]** implementation specifications.

An illustration of the HIPAA Security rule structure and its key attributes is as follows:




### HIPAA Security Rule Illustration

Required specifications must be adopted and administered as specifically dictated by the Rule.

Addressable specifications are more flexible. Individual covered entities and business associates can evaluate their own situation and determine the best way to implement addressable specifications.

The standards and specifications are as follows:

### Administrative Safeguards

This consists of policies and procedures designed to clearly show how the entity will comply with the Act. Covered entities (entities that must comply with the HIPAA requirements), must adopt a written set of privacy procedures, and designate a privacy officer to be responsible for developing and implementing all required policies and procedures. The policies and procedures must reference management oversight and demonstrate organizational buy-in to compliance with the documented security controls.

Procedures should clearly identify employees or classes of employees who will have access to ePHI. Access to ePHI must be restricted to only those employees who have a need for it to complete their designated job function. The procedures must address access authorization, establishment, modification, and termination. Entities must show that an appropriate ongoing training program regarding the handling of ePHI is provided to employees performing health plan administrative functions.

Covered entities that out-source some of their business processes to a third party must ensure that their vendors also have a framework in place to comply with HIPAA requirements. Companies typically gain this assurance through clauses in the contracts stating that the vendor will meet the same data protection requirements that apply to the covered entity. Care must be taken to determine if the vendor further out-sources any data handling functions to other vendors and monitor whether appropriate contracts and controls are in place.

Downloaded at Fri, 11 Apr 2025 15:56:26 GMT
Downloaded by asad@cloudcontrolstudio.com

A contingency plan needs to be in place for responding to emergencies. Covered entities are responsible for backing up their data and having disaster recovery procedures in place. The plan should document data priority and failure analysis, testing activities, and change control procedures.

Internal audits play a key role in HIPAA compliance by reviewing operations with the goal of identifying potential security violations. Policies and procedures should specifically document the scope, frequency, and procedures of audits. Audits should be both routine and event based.

Procedures should document instructions for addressing and responding to security breaches that are identified either during the audit or the normal course of operations.

## Physical Safeguards

Controlling physical access to protect against inappropriate access to protected data is required.

Controls must govern the introduction and removal of hardware and software from the network. (When equipment is retired it must be disposed of properly to ensure that PHI is not compromised.) Access to equipment containing health information should be carefully controlled and monitored. Access to hardware and software must be limited to properly authorized individuals. Required access controls consist of facility security plans, maintenance records, and visitor sign-in and escorts.

Policies are required to address proper workstation use. Workstations should be removed from high traffic areas and monitor screens should not be in direct view of the public. If the covered entities utilize contractors or agents, they too must be fully trained on their physical access responsibilities.

## Technical Safeguards

Controlling access to computer systems and enabling covered entities to protect communications containing PHI transmitted electronically over open networks from being intercepted by anyone other than the intended recipient is required.

Information systems housing PHI must be protected from intrusion. When information flows over open networks, some form of encryption must be utilized. If closed systems / networks are utilized, existing access controls are considered sufficient, and encryption is optional.

Each covered entity is responsible for ensuring that the data within its systems has not been changed or erased in an unauthorized manner.

Data corroboration, including the use of check sum, double-keying, message authentication, and digital signature may be used to ensure data integrity.

Covered entities must also authenticate entities with whom it communicates. Authentication consists of corroborating that an entity is who it claims to be. Examples of corroboration include password systems, two or three-way handshakes, telephone callback, and token systems.

Covered entities must make documentation of their HIPAA practices available to the government to determine compliance. In addition to policies and procedures and access records, information technology documentation should also include a written record of all configuration settings on the components of the network because these components are complex, configurable, and always changing.

Documented risk analysis and risk management programs are required. Covered entities must carefully consider the risks of their operations as they implement systems to comply with the regulations. (The requirement of risk analysis and risk management implies that the act's security requirements are a minimum standard and places responsibility on covered entities to take all reasonable precautions necessary to prevent PHI from being used for non-health purposes.)

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolsaudit.com

## Approach to Addressability for this Assessment

The tests of controls included in Section 6 of this report are based on a review of the applicable safeguards to protect ePHI at Anthropic's cloud environments. The scope of the project undertaken did not include final determinations of addressability for each requirement / rule.

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

## SECTION 6:

## CONTROL DESCRIPTIONS AND TEST OF CONTROLS

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

## INFORMATION PROVIDED BY THE ASSESSOR

### Introduction

The purpose of this section is to identify controls implemented by Anthropic to address the HIPAA requirements / rules as they relate to the services provided to entities by Anthropic. It is not the intention of this assessment to determine if the controls implemented by Anthropic satisfy the requirement / rule. Each recipient of this assessment must determine if the controls implemented by Anthropic are satisfactory to meet its own unique requirements as they relate to compliance with the HIPAA Security Final Rule.

360 Advanced recommends that each covered entity confer with its Senior Management, HIPAA Compliance Officer, and Legal Counsel on a regular basis to review and discuss HIPAA compliance and how to apply and interpret the HITECH Act's relevance and application to its business operations as they continue to change from the introduction of new services, hardware, software, or the creation of new functional business units within the enterprise.

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

## Types of Tests Performed

The table below describes the nature of our examination procedures and detailed in the matrices that follow:

| Test Types | Description of Tests |
|---|---|
| Inquiry / Interview | Inquired of appropriate personnel seeking relevant information or representation to obtain the following information about the control:<br>➢ Knowledge and additional information regarding the policy or procedure; and<br>➢ Corroborating evidence of the policy or procedure. |
| Inspection | Inspected documents and records indicating performance of the control. This includes, but is not limited to, the following:<br>➢ Examination / Inspection of source documentation and authorizations to verify transactions processed;<br>➢ Examination / Inspection of documents or records for evidence of performance, such as existence of initials or signatures;<br>➢ Examination / Inspection of systems documentation, configurations and settings; and<br>➢ Examination / Inspection of procedural documentation such as operations manuals, flow charts and job descriptions. |
| Observation | Observed the implementation, application or existence of specific controls as represented |

Downloaded at Fri 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

## Testing Matrices

## §164.308 Administrative Safeguards

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| **§164.308(a)(1)(i) Security Management Process:** Implement policies and procedures to prevent, detect, contain, and correct security violations. | | | |
| CTL-007 | A DR plan is in place and available to guide personnel in the event of an unexpected disruption in operations. | Inquired of the HIPAA Security Officer to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations. | No exceptions noted. |
| | | Inspected the Business Continuity and Disaster Recovery Plan to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations. | No exceptions noted. |
| CTL-040 | Management has documented a code of business conduct and ethical standards, which includes a sanctions policy for personnel who violate the code of business conduct. | Inquired of the HIPAA Security Officer to verify that management has documented a code of business conduct and ethical standards, which includes a sanctions policy for personnel who violate the code of business conduct. | No exceptions noted. |
| | | Inspected the Code of Conduct to verify that management has documented a code of business conduct and ethical standards, which includes a sanctions policy for personnel who violate the code of business conduct. | No exceptions noted. |
| CTL-049 | Information security policies and procedures are documented, available to guide personnel, and updated annually. | Inquired of the HIPAA Security Officer to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis. | No exceptions noted. |
| | | Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months. | No exceptions noted. |

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by ccadmin@controlstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-071 | Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded. | Inquired of the Detection and Response Security Engineer to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| | | Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| **§164.308(a)(1)(ii)(A) Risk Analysis [R]:** Conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of electronic protected health information held by the covered entity or business associate. | | | |
| CTL-003 | Annually, a risk assessment is performed by management and includes identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. | Inquired of the HIPAA Security Officer to verify that a risk assessment was performed by management on an annual basis and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. | No exceptions noted. |
| | | Inspected the risk registry to verify that a risk assessment was performed by management within the past 12 months and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. | No exceptions noted. |
| CTL-009 | An asset inventory is maintained to catalog where confidential data is stored. | Inquired of the HIPAA Security Officer to verify that an asset inventory was maintained to catalog where confidential data was stored. | No exceptions noted. |
| | | Inspected the asset classification labels to verify that an asset inventory was maintained to catalog where confidential data was stored. | No exceptions noted. |
| CTL-036 | Weekly, Executive Management meets to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | Inquired of the HIPAA Security Officer to verify that executive management met on a weekly basis to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | No exceptions noted. |

Downloaded by [illegible] on 15:56:36 GMT
Downloaded by [illegible]@controlstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the meeting minutes for a sample of weeks within the past 12 months to verify that executive management met on a weekly basis to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | No exceptions noted. |
| CTL-037 | Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments. | Inquired of the HIPAA Security Officer to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments. | No exceptions noted. |
| | | Inspected the organization's Executive Risk Council meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments. | No exceptions noted. |
| CTL-055 | Continuously, vulnerability scans are performed to identify weaknesses and vulnerabilities on systems hosting the applications in scope. | Inquired of the Detection and Response Security Engineer to verify that vulnerability scans were performed on a continuous basis to identify weaknesses and vulnerabilities on systems hosting the applications in scope. | No exceptions noted. |
| | | Inspected the vulnerability scan configuration and an example of a scan to verify that vulnerability scans were performed on a continuous basis to identify weaknesses and vulnerabilities on systems hosting the applications in scope. | No exceptions noted. |
| **§164.308(a)(1)(ii)(B) Risk Management [R]:** Implement security measures sufficient to reduce risks and vulnerabilities to a reasonable and appropriate level to comply with §164.306(a). | | | |
| CTL-010 | The malware software is configured to perform continuous scans and signature updates on servers. | Inquired of the HIPAA Security Officer to verify that the malware software was configured to perform continuous scans and signature updates on servers. | No exceptions noted. |

Downloaded at 10, 11 Apr 2025 15:56:36 GMT
Downloaded by asaad@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the antivirus dashboard and antivirus enabled on servers to verify that the malware software was configured to perform continuous scans and signature updates on servers. | No exceptions noted. |
| CTL-043 | Patch management software is utilized to monitor current patch levels of servers. | Inquired of the Infrastructure Engineer to verify that patch management software was utilized to monitor current patch levels of servers. | No exceptions noted. |
| | | Inspected the patching configurations to verify that patch management software was utilized to monitor current patch levels of servers. | No exceptions noted. |
| CTL-049 | Information security policies and procedures are documented, available to guide personnel, and updated annually. | Inquired of the HIPAA Security Officer to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis. | No exceptions noted. |
| | | Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months. | No exceptions noted. |
| CTL-061 | Annually, management obtains and reviews the sub-service organizations' Service Auditor's reports to monitor and evaluate the design and operating effectiveness of controls in place within the cloud service provider environment regarding the following responsibilities:<br>➢ Physical security and access controls<br>➢ Environmental safeguards<br>➢ Asset and media protection and destruction.<br>➢ Management of cryptographic encryption keys | Inquired of the HIPAA Security Officer to verify that management obtains and reviews the sub-service organizations' Service Auditor's reports on an annual basis to monitor and evaluate the design and operating effectiveness of controls in place within the cloud service provider environment regarding the following responsibilities:<br>➢ Physical security and access controls<br>➢ Environmental safeguards<br>➢ Asset and media protection and destruction.<br>➢ Management of cryptographic encryption keys | No exceptions noted. |

Downloaded on Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@securitycontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the most recent SOC 2 reports for AWS and GCP and management's review to verify that management obtained and reviewed the sub-service organizations' Service Auditor's reports within the past 12 months to monitor and evaluate the design and operating effectiveness of controls in place within the cloud service provider environment regarding the following responsibilities:<br>➢ Physical security and access controls<br>➢ Environmental safeguards<br>➢ Asset and media protection and destruction.<br>➢ Management of cryptographic encryption keys | No exceptions noted. |
| CTL-071 | Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded. | Inquired of the Detection and Response Security Engineer to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| | | Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| **§164.308(a)(1)(ii)(C) Sanction Policy [R]:** Apply appropriate sanctions against workforce members who fail to comply with the security policies and procedures of the covered entity or business associate. | | | |
| CTL-040 | Management has documented a code of business conduct and ethical standards, which includes a sanctions policy for personnel who violate the code of business conduct. | Inquired of the HIPAA Security Officer to verify that management has documented a code of business conduct and ethical standards, which includes a sanctions policy for personnel who violate the code of business conduct. | No exceptions noted. |
| | | Inspected the Code of Conduct to verify that management has documented a code of business conduct and ethical standards, which includes a sanctions policy for personnel who violate the code of business conduct. | No exceptions noted. |

Downloaded on Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asaf@auditcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-077 | Security commitments are communicated through the Terms of Service which is available on the customer facing website. | Inquired of the HIPAA Security Officer to verify that security commitments were communicated through the Terms of Service which was available on the customer facing website. | No exceptions noted. |
| | | Inspected the terms of service on the company website to verify that security commitments were communicated through the terms of service which was available on the customer facing website. | No exceptions noted. |
| **§164.308(a)(1)(ii)(D) Information System Activity Review [R]:** Implement procedures to regularly review records of information system activity, such as audit logs, access reports, and security incident tracking reports. | | | |
| CTL-003 | Annually, a risk assessment is performed by management and includes identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. | Inquired of the HIPAA Security Officer to verify that a risk assessment was performed by management on an annual basis and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. | No exceptions noted. |
| | | Inspected the risk registry to verify that a risk assessment was performed by management within the past 12 months and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. | No exceptions noted. |
| CTL-004 | Incident response procedures are maintained and available to guide personnel when responding to security incidents and breaches. | Inquired of the Detection and Response Security Engineer to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches. | No exceptions noted. |
| | | Inspected the incident response plan to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches. | No exceptions noted. |
| CTL-036 | Weekly, Executive Management meets to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | Inquired of the HIPAA Security Officer to verify that executive management met on a weekly basis to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | No exceptions noted. |

Downloaded on Fri, 17 Mar 2023 15:56:36 GMT
Downloaded by ashish@complianceforstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the meeting minutes for a sample of weeks within the past 12 months to verify that executive management met on a weekly basis to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | No exceptions noted. |
| CTL-037 | Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments. | Inquired of the HIPAA Security Officer to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments. | No exceptions noted. |
| | | Inspected the organization's Executive Risk Council meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments. | No exceptions noted. |
| CTL-071 | Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded. | Inquired of the Detection and Response Security Engineer to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| | | Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| **§164.308(a)(2) Assigned Security Responsibility [R]:** Identify the security official who is responsible for the development and implementation of the policies and procedures required by this subpart for the entity or business associate. | | | |
| CTL-049 | Information security policies and procedures are documented, available to guide personnel, and updated annually. | Inquired of the HIPAA Security Officer to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis. | No exceptions noted. |

Downloaded at 10, 11 Apr 2025 15:56:36 GMT
Downloaded by asaxena@controlstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months. | No exceptions noted. |
| CTL-050 | The CISO is the policy owner responsible for the development and implementation of policies and procedures. | Inquired of the HIPAA Security Officer to verify that the CISO was the policy owner responsible for the development and implementation of policies and procedures. | No exceptions noted. |
| | | Inspected the Information Security Policy to verify that the CISO was the policy owner responsible for the development and implementation of policies and procedures. | No exceptions noted. |
| **§164.308(a)(3)(i) Workforce Security:** Implement policies and procedures to ensure that all members of its workforce have appropriate access to electronic protected health information, as provided under paragraph (a)(4) of this section, and to prevent those workforce members who do not have access under paragraph (a)(4) of this section from obtaining access to electronic protected health information. | | | |
| CTL-002 | Role-based permissions are used to restrict access to the application administration interface. | Inquired of the HIPAA Security Officer to verify that role-based permissions were used to restrict access to the application administration interface. | No exceptions noted. |
| | | Inspected the assignable access roles and permissions to verify that role-based permissions were used to restrict access to the application administration interface. | No exceptions noted. |
| CTL-024 | Internal user access is provisioned based on a pre-defined role-based access matrix. | Inquired of the HIPAA Security Officer to verify that internal user access was provisioned based on a pre-defined role-based access matrix. | No exceptions noted. |
| | | Inspected the role-based access configurations and role assignment for a recently onboarded user to verify that internal user access was provisioned based on a pre-defined role-based access matrix. | No exceptions noted. |
| CTL-031 | Accounts assigned to terminated non-privileged users are disabled or deleted upon termination. | Inquired of the HIPAA Security Officer to verify that accounts assigned to terminated non-privileged users were disabled or deleted upon termination. | No exceptions noted. |

Downloaded on Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@securitycontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the offboarding records and account statuses for a sample of non-privileged users offboarded within the past 12 months to verify that accounts assigned to terminated non-privileged users were disabled or deleted upon termination. | Exceptions noted.<br>360 Advanced noted that three out of five non-privileged users' access was not disabled or deleted upon termination.<br>See Section 7 for information provided by management that is not covered by the service auditor's report. |
| CTL-032 | Accounts assigned to terminated privileged users are disabled or deleted upon termination. | Inquired of the HIPAA Security Officer to verify that accounts assigned to terminated privileged users were disabled or deleted upon termination. | No exceptions noted. |
| | | Inspected the offboarding records and account statuses for a sample of privileged users offboarded within the past 12 months to verify that accounts assigned to terminated privileged users were disabled or deleted upon termination. | No exceptions noted. |
| **§164.308(a)(3)(ii)(A) Authorization and / or Supervision [A]:** Implement procedures for the authorization and / or supervision of workforce members who work with electronic protected health information or in locations where it might be accessed. | | | |
| CTL-024 | Internal user access is provisioned based on a pre-defined role-based access matrix. | Inquired of the HIPAA Security Officer to verify that internal user access was provisioned based on a pre-defined role-based access matrix. | No exceptions noted. |
| | | Inspected the role-based access configurations and role assignment for a recently onboarded user to verify that internal user access was provisioned based on a pre-defined role-based access matrix. | No exceptions noted. |
| CTL-027 | Upon hire, employees are required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties. | Inquired of the HIPAA Security Officer to verify that upon hire, employees were required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties. | No exceptions noted. |

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asset@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the executed confidentiality acknowledgement for a sample of users onboarded within the past 12 months to verify that upon hire, employees were required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties. | No exceptions noted. |
| CTL-028 | Background screenings are performed for employment candidates as a component of the hiring process. | Inquired of the HIPAA Security Officer to verify that background screenings were performed for employment candidates as a component of the hiring process. | No exceptions noted. |
| | | Inspected the completed background screening for a sample of users onboarded within the past 12 months to verify that background screenings were performed for employment candidates as a component of the hiring process. | No exceptions noted. |
| CTL-049 | Information security policies and procedures are documented, available to guide personnel, and updated annually. | Inquired of the HIPAA Security Officer to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis. | No exceptions noted. |
| | | Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months. | No exceptions noted. |
| CTL-060 | Annually, a vendor review is performed that includes identifying and assessing the risks associated with third parties. | Inquired of the HIPAA Security Officer to verify that a vendor review was performed on an annual basis that included identifying and assessing the risks associated with third parties. | No exceptions noted. |
| | | Inspected the due diligence records for a sample of active vendors to verify that a vendor review was performed within the past 12 months that included identifying and assessing the risks associated with third parties. | No exceptions noted. |

Downloaded by asim@studentfirstudio.com, 11 Apr 2025 15:56:36 GMT

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| **§164.308(a)(3)(ii)(B) Workforce Clearance Procedure [A]:** Implement procedures that determine that the access of a workforce member to electronic protected health information is appropriate. | | | |
| CTL-002 | Role-based permissions are used to restrict access to the application administration interface. | Inquired of the HIPAA Security Officer to verify that role-based permissions were used to restrict access to the application administration interface. | No exceptions noted. |
| | | Inspected the assignable access roles and permissions to verify that role-based permissions were used to restrict access to the application administration interface. | No exceptions noted. |
| CTL-069 | The cloud management console access authentication parameters are configured to require a unique user ID, complex password, and 2FA. | Inquired of the Infrastructure Engineer to verify that the cloud management console access authentication parameters were configured to require a unique user ID, complex password, and 2FA. | No exceptions noted. |
| | | Inspected the authentication configurations to verify that the cloud management console access authentication parameters were configured to require a unique user ID, complex password, and 2FA. | No exceptions noted. |
| **§164.308(a)(3)(ii)(C) Termination Procedures [A]:** Implement procedures for terminating access to electronic protected health information when the employment of a workforce member ends or as required by determinations made as specified in paragraph (a)(3)(ii)(B) of this section. | | | |
| CTL-031 | Accounts assigned to terminated non-privileged users are disabled or deleted upon termination. | Inquired of the HIPAA Security Officer to verify that accounts assigned to terminated non-privileged users were disabled or deleted upon termination. | No exceptions noted. |
| | | Inspected the offboarding records and account statuses for a sample of non-privileged users offboarded within the past 12 months to verify that accounts assigned to terminated non-privileged users were disabled or deleted upon termination. | Exceptions noted.<br>360 Advanced noted that three out of five non-privileged users' access was not disabled or deleted upon termination.<br>See Section 7 for information provided by management that is not covered by the service auditor's report. |

Downloaded at 11:11 AM, 11-Apr-2026 15:50:16 GMT
Downloaded by aadam@auditcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-032 | Accounts assigned to terminated privileged users are disabled or deleted upon termination. | Inquired of the HIPAA Security Officer to verify that accounts assigned to terminated privileged users were disabled or deleted upon termination. | No exceptions noted. |
| | | Inspected the offboarding records and account statuses for a sample of privileged users offboarded within the past 12 months to verify that accounts assigned to terminated privileged users were disabled or deleted upon termination. | No exceptions noted. |
| CTL-034 | Procedures are documented in a termination checklist to guide personnel during the off-boarding process. | Inquired of the HIPAA Security Officer to verify that procedures were documented in a termination checklist to guide personnel during the off-boarding process. | No exceptions noted. |
| | | Inspected the offboarding checklist to verify that procedures were documented in a termination checklist to guide personnel during the off-boarding process. | No exceptions noted. |
| **§164.308(a)(4)(i) Information Access Management:** Implement policies and procedures for authorizing access to electronic protected health information that are consistent with the applicable requirements of subpart E of this part. | | | |
| CTL-024 | Internal user access is provisioned based on a pre-defined role-based access matrix. | Inquired of the HIPAA Security Officer to verify that internal user access was provisioned based on a pre-defined role-based access matrix. | No exceptions noted. |
| | | Inspected the role-based access configurations and role assignment for a recently onboarded user to verify that internal user access was provisioned based on a pre-defined role-based access matrix. | No exceptions noted. |
| CTL-026 | Upon hire, employees are required to sign acceptance of the Information Security Policy. | Inquired of the HIPAA Security Officer to verify that upon hire, employees were required to sign acceptance of the Information Security Policy. | No exceptions noted. |

Downloaded on Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asha@claudiatrdstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the information security policy acknowledgements for a sample of users onboarded within the past 12 months to verify that upon hire, employees were required to sign acceptance of the information security policy. | Exceptions noted.<br>360 Advanced noted that 13 out of 40 sampled users onboarded during the examination period did not acknowledge the information security policy.<br>See Section 7 for information provided by management that is not covered by the service auditor's report. |
| CTL-027 | Upon hire, employees are required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties. | Inquired of the HIPAA Security Officer to verify that upon hire, employees were required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties. | No exceptions noted. |
| | | Inspected the executed confidentiality acknowledgement for a sample of users onboarded within the past 12 months to verify that upon hire, employees were required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties. | No exceptions noted. |
| CTL-028 | Background screenings are performed for employment candidates as a component of the hiring process. | Inquired of the HIPAA Security Officer to verify that background screenings were performed for employment candidates as a component of the hiring process. | No exceptions noted. |
| | | Inspected the completed background screening for a sample of users onboarded within the past 12 months to verify that background screenings were performed for employment candidates as a component of the hiring process. | No exceptions noted. |
| CTL-060 | Annually, a vendor review is performed that includes identifying and assessing the risks associated with third parties. | Inquired of the HIPAA Security Officer to verify that a vendor review was performed on an annual basis that included identifying and assessing the risks associated with third parties. | No exceptions noted. |

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the due diligence records for a sample of active vendors to verify that a vendor review was performed within the past 12 months that included identifying and assessing the risks associated with third parties. | No exceptions noted. |
| **§164.308(a)(4)(ii)(A) Isolating Health Care Clearinghouse Functions [R]:** If a health care clearinghouse is part of a larger organization, the clearinghouse must implement policies and procedures that protect the electronic protected health information of the clearinghouse from unauthorized access by the larger organization. | | | |
| N/A - Anthropic is not considered a clearinghouse. | | | |
| **§164.308(a)(4)(ii)(B) Access Authorization [A]:** Implement policies and procedures for granting access to electronic protected health information, for example, through access to a work station, transaction, program, process, or other mechanism. | | | |
| CTL-024 | Internal user access is provisioned based on a pre-defined role-based access matrix. | Inquired of the HIPAA Security Officer to verify that internal user access was provisioned based on a pre-defined role-based access matrix. | No exceptions noted. |
| | | Inspected the role-based access configurations and role assignment for a recently onboarded user to verify that internal user access was provisioned based on a pre-defined role-based access matrix. | No exceptions noted. |
| CTL-026 | Upon hire, employees are required to sign acceptance of the Information Security Policy. | Inquired of the HIPAA Security Officer to verify that upon hire, employees were required to sign acceptance of the Information Security Policy. | No exceptions noted. |
| | | Inspected the information security policy acknowledgements for a sample of users onboarded within the past 12 months to verify that upon hire, employees were required to sign acceptance of the information security policy. | Exceptions noted.<br>360 Advanced noted that 13 out of 40 sampled users onboarded during the examination period did not acknowledge the information security policy.<br>See Section 7 for information provided by management that is not covered by the service auditor's report. |

Downloaded at Fri, 11 Apr 2025 15:56:16 GMT
Downloaded by asad@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-027 | Upon hire, employees are required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties. | Inquired of the HIPAA Security Officer to verify that upon hire, employees were required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties. | No exceptions noted. |
| | | Inspected the executed confidentiality acknowledgement for a sample of users onboarded within the past 12 months to verify that upon hire, employees were required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties. | No exceptions noted. |
| CTL-028 | Background screenings are performed for employment candidates as a component of the hiring process. | Inquired of the HIPAA Security Officer to verify that background screenings were performed for employment candidates as a component of the hiring process. | No exceptions noted. |
| | | Inspected the completed background screening for a sample of users onboarded within the past 12 months to verify that background screenings were performed for employment candidates as a component of the hiring process. | No exceptions noted. |
| CTL-049 | Information security policies and procedures are documented, available to guide personnel, and updated annually. | Inquired of the HIPAA Security Officer to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis. | No exceptions noted. |
| | | Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months. | No exceptions noted. |
| CTL-060 | Annually, a vendor review is performed that includes identifying and assessing the risks associated with third parties. | Inquired of the HIPAA Security Officer to verify that a vendor review was performed on an annual basis that included identifying and assessing the risks associated with third parties. | No exceptions noted. |

Downloaded on 11 Apr 2025 15:56:36 GMT
Downloaded by aaad@studentmstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the due diligence records for a sample of active vendors to verify that a vendor review was performed within the past 12 months that included identifying and assessing the risks associated with third parties. | No exceptions noted. |
| **§164.308(a)(4)(ii)(C) Access Establishment and Modification [A]:** Implement policies and procedures that, based upon the entity's or the business associate's access authorization policies, establish, document, review, and modify a user's right of access to a workstation, transaction, program, or process. | | | |
| CTL-002 | Role-based permissions are used to restrict access to the application administration interface. | Inquired of the HIPAA Security Officer to verify that role-based permissions were used to restrict access to the application administration interface. | No exceptions noted. |
| | | Inspected the assignable access roles and permissions to verify that role-based permissions were used to restrict access to the application administration interface. | No exceptions noted. |
| CTL-024 | Internal user access is provisioned based on a pre-defined role-based access matrix. | Inquired of the HIPAA Security Officer to verify that internal user access was provisioned based on a pre-defined role-based access matrix. | No exceptions noted. |
| | | Inspected the role-based access configurations and role assignment for a recently onboarded user to verify that internal user access was provisioned based on a pre-defined role-based access matrix. | No exceptions noted. |
| CTL-031 | Accounts assigned to terminated non-privileged users are disabled or deleted upon termination. | Inquired of the HIPAA Security Officer to verify that accounts assigned to terminated non-privileged users were disabled or deleted upon termination. | No exceptions noted. |
| | | Inspected the offboarding records and account statuses for a sample of non-privileged users offboarded within the past 12 months to verify that accounts assigned to terminated non-privileged users were disabled or deleted upon termination. | Exceptions noted.<br>360 Advanced noted that three out of five non-privileged users' access was not disabled or deleted upon termination.<br>See Section 7 for information provided by management that is not covered by the service auditor's report. |

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@360controlstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-032 | Accounts assigned to terminated privileged users are disabled or deleted upon termination. | Inquired of the HIPAA Security Officer to verify that accounts assigned to terminated privileged users were disabled or deleted upon termination. | No exceptions noted. |
| | | Inspected the offboarding records and account statuses for a sample of privileged users offboarded within the past 12 months to verify that accounts assigned to terminated privileged users were disabled or deleted upon termination. | No exceptions noted. |
| CTL-049 | Information security policies and procedures are documented, available to guide personnel, and updated annually. | Inquired of the HIPAA Security Officer to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis. | No exceptions noted. |
| | | Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months. | No exceptions noted. |
| **§164.308(a)(5)(i) Security Awareness and Training:** Implement a security awareness and training program for all members of its workforce (including management). | | | |
| CTL-025 | Upon hire, users are required to complete security awareness training. | Inquired of the HIPAA Security Officer to verify that upon hire, users were required to complete security awareness training. | No exceptions noted. |
| | | Inspected the completed security awareness training records for a sample of users onboarded within the past 12 months to verify that upon hire, users were required to complete security awareness training. | Exceptions noted.<br>360 Advanced noted that three out of 40 sampled users onboarded during the examination period did not complete security awareness training.<br>See Section 7 for information provided by management that is not covered by the service auditor's report. |
| CTL-026 | Upon hire, employees are required to sign acceptance of the Information Security Policy. | Inquired of the HIPAA Security Officer to verify that upon hire, employees were required to sign acceptance of the Information Security Policy. | No exceptions noted. |

Downloaded on Tue, 11 Nov 2025 15:56:36 GMT
Downloaded by asad@cbuncontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the information security policy acknowledgements for a sample of users onboarded within the past 12 months to verify that upon hire, employees were required to sign acceptance of the information security policy. | Exceptions noted.<br>360 Advanced noted that 13 out of 40 sampled users onboarded during the examination period did not acknowledge the information security policy.<br>See Section 7 for information provided by management that is not covered by the service auditor's report. |
| CTL-029 | Annually, users are required to complete security awareness training. | Inquired of the HIPAA Security Officer to verify that users were required to complete security awareness training on an annual basis. | No exceptions noted. |
| | | Inspected the completed security awareness training records for a sample of tenured users to verify that employees were required to complete security awareness training within the past 12 months. | Exceptions noted.<br>360 Advanced noted that 11 out of 22 sampled users did not complete security awareness training in the last 12 months.<br>See Section 7 for information provided by management that is not covered by the service auditor's report. |
| **§164.308(a)(5)(ii)(A) Security Reminders [A]:** Periodic security updates. | | | |
| CTL-025 | Upon hire, users are required to complete security awareness training. | Inquired of the HIPAA Security Officer to verify that upon hire, users were required to complete security awareness training. | No exceptions noted. |
| | | Inspected the completed security awareness training records for a sample of users onboarded within the past 12 months to verify that upon hire, users were required to complete security awareness training. | Exceptions noted.<br>360 Advanced noted that three out of 40 sampled users onboarded during the examination period did not complete security awareness training.<br>See Section 7 for information provided by management that is not covered by the service auditor's report. |

Downloaded at Fri Jul 11 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-029 | Annually, users are required to complete security awareness training. | Inquired of the HIPAA Security Officer to verify that users were required to complete security awareness training on an annual basis. | No exceptions noted. |
| | | Inspected the completed security awareness training records for a sample of tenured users to verify that employees were required to complete security awareness training within the past 12 months. | Exceptions noted.<br>360 Advanced noted that 11 out of 22 sampled users did not complete security awareness training in the last 12 months.<br>See Section 7 for information provided by management that is not covered by the service auditor's report. |
| CTL-049 | Information security policies and procedures are documented, available to guide personnel, and updated annually. | Inquired of the HIPAA Security Officer to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis. | No exceptions noted. |
| | | Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months. | No exceptions noted. |
| **§164.308(a)(5)(ii)(B) Protection from Malicious Software [A]:** Procedures for guarding against, detecting, and reporting malicious software. | | | |
| CTL-010 | The malware software is configured to perform continuous scans and signature updates on servers. | Inquired of the HIPAA Security Officer to verify that the malware software was configured to perform continuous scans and signature updates on servers. | No exceptions noted. |
| | | Inspected the antivirus dashboard and antivirus enabled on servers to verify that the malware software was configured to perform continuous scans and signature updates on servers. | No exceptions noted. |
| CTL-043 | Patch management software is utilized to monitor current patch levels of servers. | Inquired of the Infrastructure Engineer to verify that patch management software was utilized to monitor current patch levels of servers. | No exceptions noted. |

Downloaded on Fri, 11 Apr 2025 19:56:36 GMT
Downloaded by asha@secondcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the patching configurations to verify that patch management software was utilized to monitor current patch levels of servers. | No exceptions noted. |
| CTL-071 | Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded. | Inquired of the Detection and Response Security Engineer to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| | | Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| **§164.308(a)(5)(ii)(C) Log-in Monitoring [A]:** Procedures for monitoring log-in attempts and reporting discrepancies. | | | |
| CTL-006 | A system is in place to monitor and track security events from identification to resolution. | Inquired of the Detection and Response Security Engineer to verify that a system was in place to monitor and track security events from identification to resolution. | No exceptions noted. |
| | | Inspected the event ticket logs to verify that a system was in place to monitor and track security events from identification to resolution. | No exceptions noted. |
| CTL-071 | Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded. | Inquired of the Detection and Response Security Engineer to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| | | Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| **§164.308(a)(5)(ii)(D) Password Management [A]:** Procedures for creating, changing, and safeguarding passwords. | | | |

Downloaded on Fri, 11 Mar 2026 15:56:36 GMT
Downloaded by csaad@cloudconformstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-001 | Access to the application is restricted via a unique username and password. | Inquired of the HIPAA Security Officer to verify that access to the application was restricted via a unique username and password. | No exceptions noted. |
| | | Inspected the application login prompt and password configurations to verify that access to the application was restricted via a unique username and password. | No exceptions noted. |
| CTL-002 | Role-based permissions are used to restrict access to the application administration interface. | Inquired of the HIPAA Security Officer to verify that role-based permissions were used to restrict access to the application administration interface. | No exceptions noted. |
| | | Inspected the assignable access roles and permissions to verify that role-based permissions were used to restrict access to the application administration interface. | No exceptions noted. |
| CTL-069 | The cloud management console access authentication parameters are configured to require a unique user ID, complex password, and 2FA. | Inquired of the Infrastructure Engineer to verify that the cloud management console access authentication parameters were configured to require a unique user ID, complex password, and 2FA. | No exceptions noted. |
| | | Inspected the authentication configurations to verify that the cloud management console access authentication parameters were configured to require a unique user ID, complex password, and 2FA. | No exceptions noted. |
| **§164.308(a)(6)(i) Security Incident Procedures:** Implement policies and procedures to address security incidents. | | | |
| CTL-004 | Incident response procedures are maintained and available to guide personnel when responding to security incidents and breaches. | Inquired of the Detection and Response Security Engineer to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches. | No exceptions noted. |
| | | Inspected the incident response plan to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches. | No exceptions noted. |

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by andre@totalcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-036 | Weekly, Executive Management meets to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | Inquired of the HIPAA Security Officer to verify that executive management met on a weekly basis to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | No exceptions noted. |
| | | Inspected the meeting minutes for a sample of weeks within the past 12 months to verify that executive management met on a weekly basis to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | No exceptions noted. |
| CTL-037 | Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments. | Inquired of the HIPAA Security Officer to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments. | No exceptions noted. |
| | | Inspected the organization's Executive Risk Council meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments. | No exceptions noted. |
| CTL-042 | A cyber insurance policy is maintained to offset the financial impact incurred by the company in the event of a security incident or data breach. | Inquired of the HIPAA Security Officer to verify that a cyber insurance policy was maintained to offset the financial impact incurred by the company in the event of a security incident or data breach. | No exceptions noted. |
| | | Inspected the cyber insurance policy to verify that a cyber insurance policy was maintained to offset the financial impact incurred by the company in the event of a security incident or data breach. | No exceptions noted. |
| CTL-049 | Information security policies and procedures are documented, available to guide personnel, and updated annually. | Inquired of the HIPAA Security Officer to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis. | No exceptions noted. |

Downloaded on, 11 Apr 2025 15:56:36 GMT
Downloaded by asaad@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months. | No exceptions noted. |
| **§164.308(a)(6)(ii) Response and Reporting [R]:** Identify and respond to suspected or known security incidents; mitigate, to the extent practicable, harmful effects of security incidents that are known to the covered entity or business associate; and document security incidents and their outcomes. | | | |
| CTL-004 | Incident response procedures are maintained and available to guide personnel when responding to security incidents and breaches. | Inquired of the Detection and Response Security Engineer to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches. | No exceptions noted. |
| | | Inspected the incident response plan to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches. | No exceptions noted. |
| CTL-068 | Quarterly, all-hands meetings are held to discuss operational, IT, and client related topics. | Inquired of the HIPAA Security Officer to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics. | No exceptions noted. |
| | | Inspected the all-hands meeting slide deck for a sample of quarters within the past 12 months to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics. | No exceptions noted. |
| CTL-071 | Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded. | Inquired of the Detection and Response Security Engineer to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| | | Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| **§164.308(a)(7)(i) Contingency Plan:** Establish (and implement as needed) policies and procedures for responding to an emergency or other occurrence (for example: fire, vandalism, system failure, and natural disaster) that damages systems that contain electronic protected health information. | | | |

Downloaded at Fri, 12 Apr 2024 15:56:36 GMT
Downloaded by aaron@thecontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-007 | A DR plan is in place and available to guide personnel in the event of an unexpected disruption in operations. | Inquired of the HIPAA Security Officer to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations. | No exceptions noted. |
| | | Inspected the Business Continuity and Disaster Recovery Plan to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations. | No exceptions noted. |
| CTL-008 | Annually, the DR plan is tested and updated. | Inquired of the HIPAA Security Officer to verify that the DR plan was tested and updated on an annual basis. | No exceptions noted. |
| | | Inspected the DR test exercise and post meeting report to verify that the DR plan was tested and updated within the past 12 months. | No exceptions noted. |
| CTL-042 | A cyber insurance policy is maintained to offset the financial impact incurred by the company in the event of a security incident or data breach. | Inquired of the HIPAA Security Officer to verify that a cyber insurance policy was maintained to offset the financial impact incurred by the company in the event of a security incident or data breach. | No exceptions noted. |
| | | Inspected the cyber insurance policy to verify that a cyber insurance policy was maintained to offset the financial impact incurred by the company in the event of a security incident or data breach. | No exceptions noted. |
| **§164.308(a)(7)(ii)(A) Data Backup Plan [R]:** Establish and implement procedures to create and maintain retrievable exact copies of electronic protected health information. | | | |
| CTL-012 | Daily, a backup job scheduler is configured to perform backups of the production system. | Inquired of the Infrastructure Engineer to verify that a backup job scheduler was configured to perform backups of the production system on a daily basis. | No exceptions noted. |
| | | Inspected the backup configurations to verify that a backup job scheduler was configured to perform backups of the production system on a daily basis. | No exceptions noted. |
| CTL-013 | Backups are encrypted and stored separately from where the primary data source resides. | Inquired of the Security Engineer to verify that backups were encrypted and stored separately from where the primary data source resides. | No exceptions noted. |

Downloaded on Fri, 22 Apr 2022 15:56:36 GMT
Downloaded by academic@controlstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the backup encryption configurations to verify that backups were encrypted and stored separately from where the primary data source resides. | No exceptions noted. |
| CTL-014 | The backup system is configured to retain daily backups for 365 days. | Inquired of the HIPAA Security Officer to verify that the backup system was configured to retain daily backups for 365 days. | No exceptions noted. |
| | | Inspected the backup configuration to verify that the backup system was configured to retain daily backups for 365 days. | No exceptions noted. |
| CTL-045 | Backup policies and procedures are documented and available to guide personnel in the backup process. | Inquired of the HIPAA Security Officer to verify that backup policies and procedures were documented and available to guide personnel in the backup process. | No exceptions noted. |
| | | Inspected the Operations Security Policy to verify that backup policies and procedures were documented and available to guide personnel in the backup process. | No exceptions noted. |
| **§164.308(a)(7)(ii)(B) Disaster Recovery Plan [R]:** Establish (and implement as needed) procedures to restore any loss of data. | | | |
| CTL-007 | A DR plan is in place and available to guide personnel in the event of an unexpected disruption in operations. | Inquired of the HIPAA Security Officer to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations. | No exceptions noted. |
| | | Inspected the Business Continuity and Disaster Recovery Plan to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations. | No exceptions noted. |
| CTL-008 | Annually, the DR plan is tested and updated. | Inquired of the HIPAA Security Officer to verify that the DR plan was tested and updated on an annual basis. | No exceptions noted. |
| | | Inspected the DR test exercise and post meeting report to verify that the DR plan was tested and updated within the past 12 months. | No exceptions noted. |

Downloaded at Fri, 19 Apr 2024 15:56:36 GMT
Downloaded by aaadcloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| **§164.308(a)(7)(ii)(C) Emergency Mode Operation Plan [R]:** Establish (and implement as needed) Procedures to enable continuation of critical business processes for protection of the security of electronic protected health information while operating in emergency mode. | | | |
| CTL-007 | A DR plan is in place and available to guide personnel in the event of an unexpected disruption in operations. | Inquired of the HIPAA Security Officer to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations. | No exceptions noted. |
| | | Inspected the Business Continuity and Disaster Recovery Plan to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations. | No exceptions noted. |
| CTL-008 | Annually, the DR plan is tested and updated. | Inquired of the HIPAA Security Officer to verify that the DR plan was tested and updated on an annual basis. | No exceptions noted. |
| | | Inspected the DR test exercise and post meeting report to verify that the DR plan was tested and updated within the past 12 months. | No exceptions noted. |
| **§164.308(a)(7)(ii)(D) Testing and Revision Procedures [A]:** Implement procedures for periodic testing and revision of the contingency plans. | | | |
| CTL-008 | Annually, the DR plan is tested and updated. | Inquired of the HIPAA Security Officer to verify that the DR plan was tested and updated on an annual basis. | No exceptions noted. |
| | | Inspected the DR test exercise and post meeting report to verify that the DR plan was tested and updated within the past 12 months. | No exceptions noted. |
| **164.308(a)(7)(ii)(E) Applications and Data Criticality Analysis [A]:** Assess the relative criticality of specific applications and data in support of other contingency plan components. | | | |
| CTL-003 | Annually, a risk assessment is performed by management and includes identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. | Inquired of the HIPAA Security Officer to verify that a risk assessment was performed by management on an annual basis and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. | No exceptions noted. |

Downloaded at Fri, 12 Apr 2024 15:56:26 GMT
Downloaded by saas@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the risk registry to verify that a risk assessment was performed by management within the past 12 months and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. | No exceptions noted. |
| CTL-036 | Weekly, Executive Management meets to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | Inquired of the HIPAA Security Officer to verify that executive management met on a weekly basis to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | No exceptions noted. |
| | | Inspected the meeting minutes for a sample of weeks within the past 12 months to verify that executive management met on a weekly basis to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | No exceptions noted. |
| CTL-037 | Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments. | Inquired of the HIPAA Security Officer to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments. | No exceptions noted. |
| | | Inspected the organization's Executive Risk Council meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments. | No exceptions noted. |
| CTL-052 | A defined risk methodology is in place to ensure that standards exist for the treatment of risks throughout the environment to an acceptable level. | Inquired of the Detection and Response Security Engineer to verify that a defined risk methodology was in place to ensure that standards exist for the treatment of risks throughout the environment to an acceptable level. | No exceptions noted. |
| | | Inspected the Risk Management Policy to verify that a defined risk methodology was in place to ensure that standards exist for the treatment of risks throughout the environment to an acceptable level. | No exceptions noted. |

Downloaded on 11 Apr 2025 15:56:36 GMT
Downloaded by ccard@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| **§164.308(a)(8) Evaluation [R]:** Perform a periodic technical and nontechnical evaluation, based initially upon the standards implemented under this rule and subsequently, in response to environmental or operational changes affecting the security of electronic protected health information, that establishes the extent to which a covered entity's or business associate's security policies and procedures meet the requirements of this subpart. | | | |
| CTL-003 | Annually, a risk assessment is performed by management and includes identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. | Inquired of the HIPAA Security Officer to verify that a risk assessment was performed by management on an annual basis and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. | No exceptions noted. |
| | | Inspected the risk registry to verify that a risk assessment was performed by management within the past 12 months and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. | No exceptions noted. |
| CTL-036 | Weekly, Executive Management meets to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | Inquired of the HIPAA Security Officer to verify that executive management met on a weekly basis to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | No exceptions noted. |
| | | Inspected the meeting minutes for a sample of weeks within the past 12 months to verify that executive management met on a weekly basis to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | No exceptions noted. |
| CTL-037 | Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments. | Inquired of the HIPAA Security Officer to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments. | No exceptions noted. |
| | | Inspected the organization's Executive Risk Council meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments. | No exceptions noted. |

Downloaded on Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by ceadc@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-055 | Continuously, vulnerability scans are performed to identify weaknesses and vulnerabilities on systems hosting the applications in scope. | Inquired of the Detection and Response Security Engineer to verify that vulnerability scans were performed on a continuous basis to identify weaknesses and vulnerabilities on systems hosting the applications in scope. | No exceptions noted. |
| | | Inspected the vulnerability scan configuration and an example of a scan to verify that vulnerability scans were performed on a continuous basis to identify weaknesses and vulnerabilities on systems hosting the applications in scope. | No exceptions noted. |
| CTL-061 | Annually, management obtains and reviews the sub-service organizations' Service Auditor's reports to monitor and evaluate the design and operating effectiveness of controls in place within the cloud service provider environment regarding the following responsibilities:<br>➢ Physical security and access controls<br>➢ Environmental safeguards<br>➢ Asset and media protection and destruction.<br>➢ Management of cryptographic encryption keys | Inquired of the HIPAA Security Officer to verify that management obtains and reviews the sub-service organizations' Service Auditor's reports on an annual basis to monitor and evaluate the design and operating effectiveness of controls in place within the cloud service provider environment regarding the following responsibilities:<br>➢ Physical security and access controls<br>➢ Environmental safeguards<br>➢ Asset and media protection and destruction.<br>➢ Management of cryptographic encryption keys | No exceptions noted. |
| | | Inspected the most recent SOC 2 reports for AWS and GCP and management's review to verify that management obtained and reviewed the sub-service organizations' Service Auditor's reports within the past 12 months to monitor and evaluate the design and operating effectiveness of controls in place within the cloud service provider environment regarding the following responsibilities:<br>➢ Physical security and access controls<br>➢ Environmental safeguards<br>➢ Asset and media protection and destruction.<br>➢ Management of cryptographic encryption keys | No exceptions noted. |

Downloaded on 11 Apr 2025 15:56:36 GMT
Downloaded by ccc@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-068 | Quarterly, all-hands meetings are held to discuss operational, IT, and client related topics. | Inquired of the HIPAA Security Officer to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics. | No exceptions noted. |
| | | Inspected the all-hands meeting slide deck for a sample of quarters within the past 12 months to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics. | No exceptions noted. |
| **§164.308(b)(1) Business Associate Contracts and Other Arrangements [R]:** A covered entity may permit a business associate to create, receive, maintain, or transmit electronic protected health information on the covered entity's behalf only if the covered entity obtains satisfactory assurances, in accordance with § 164.314(a) that the business associate will appropriately safeguard the information. | | | |
| CTL-060 | Annually, a vendor review is performed that includes identifying and assessing the risks associated with third parties. | Inquired of the HIPAA Security Officer to verify that a vendor review was performed on an annual basis that included identifying and assessing the risks associated with third parties. | No exceptions noted. |
| | | Inspected the due diligence records for a sample of active vendors to verify that a vendor review was performed within the past 12 months that included identifying and assessing the risks associated with third parties. | No exceptions noted. |
| CTL-061 | Annually, management obtains and reviews the sub-service organizations' Service Auditor's reports to monitor and evaluate the design and operating effectiveness of controls in place within the cloud service provider environment regarding the following responsibilities:<br>➢ Physical security and access controls<br>➢ Environmental safeguards<br>➢ Asset and media protection and destruction.<br>➢ Management of cryptographic encryption keys | Inquired of the HIPAA Security Officer to verify that management obtains and reviews the sub-service organizations' Service Auditor's reports on an annual basis to monitor and evaluate the design and operating effectiveness of controls in place within the cloud service provider environment regarding the following responsibilities:<br>➢ Physical security and access controls<br>➢ Environmental safeguards<br>➢ Asset and media protection and destruction.<br>➢ Management of cryptographic encryption keys | No exceptions noted. |

Downloaded on Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asaik@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the most recent SOC 2 reports for AWS and GCP and management's review to verify that management obtained and reviewed the sub-service organizations' Service Auditor's reports within the past 12 months to monitor and evaluate the design and operating effectiveness of controls in place within the cloud service provider environment regarding the following responsibilities:<br>➢ Physical security and access controls<br>➢ Environmental safeguards<br>➢ Asset and media protection and destruction.<br>➢ Management of cryptographic encryption keys | No exceptions noted. |
| CTL-072 | During the vendor onboarding process, vendors that may come in contact with PHI sign BAAs to ensure compliance requirements and responsibilities are communicated. | Inquired of the HIPAA Security Officer to verify that during the vendor onboarding process, vendors that may come in contact with PHI signed BAAs to ensure compliance requirements and responsibilities were communicated. | No exceptions noted. |
| | | No test of the control was performed because the circumstances that warranted the operation of the control did not occur within the past 12 months. | N/A |
| **§164.308(b)(3) Written Contract or Other Arrangement [R]:** Document the satisfactory assurances required by paragraph (b)(1) of this section through a written contract or other arrangement with the business associate that meets the applicable requirements of §164.314(a). | | | |
| CTL-022 | The terms of use and privacy policy are available on the company website to provide the terms and conditions concerning the use of the site and to address privacy concerns on data that may be collected through the use of their online products and services. | Inquired of the HIPAA Security Officer to verify that the terms of use and privacy policy were available on the company website to provide the terms and conditions concerning the use of the site and to address privacy concerns on data that may be collected through the use of their online products and services. | No exceptions noted. |
| | | Inspected the Terms of Service and Privacy Policy to verify that the terms of use and privacy policy were available on the company website to provide the terms and conditions concerning the use of the site and to address privacy concerns on data that may be collected through the use of their online products and services. | No exceptions noted. |

Downloaded at: Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asaad@cloudconformstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-060 | Annually, a vendor review is performed that includes identifying and assessing the risks associated with third parties. | Inquired of the HIPAA Security Officer to verify that a vendor review was performed on an annual basis that included identifying and assessing the risks associated with third parties. | No exceptions noted. |
| | | Inspected the due diligence records for a sample of active vendors to verify that a vendor review was performed within the past 12 months that included identifying and assessing the risks associated with third parties. | No exceptions noted. |
| CTL-061 | Annually, management obtains and reviews the sub-service organizations' Service Auditor's reports to monitor and evaluate the design and operating effectiveness of controls in place within the cloud service provider environment regarding the following responsibilities:<br>➢ Physical security and access controls<br>➢ Environmental safeguards<br>➢ Asset and media protection and destruction.<br>➢ Management of cryptographic encryption keys | Inquired of the HIPAA Security Officer to verify that management obtains and reviews the sub-service organizations' Service Auditor's reports on an annual basis to monitor and evaluate the design and operating effectiveness of controls in place within the cloud service provider environment regarding the following responsibilities:<br>➢ Physical security and access controls<br>➢ Environmental safeguards<br>➢ Asset and media protection and destruction.<br>➢ Management of cryptographic encryption keys | No exceptions noted. |
| | | Inspected the most recent SOC 2 reports for AWS and GCP and management's review to verify that management obtained and reviewed the sub-service organizations' Service Auditor's reports within the past 12 months to monitor and evaluate the design and operating effectiveness of controls in place within the cloud service provider environment regarding the following responsibilities:<br>➢ Physical security and access controls<br>➢ Environmental safeguards<br>➢ Asset and media protection and destruction.<br>➢ Management of cryptographic encryption keys | No exceptions noted. |

Downloaded by [illegible] on 11 Apr 2025 15:56:36 GMT
Downloaded by [illegible]@cloudsecurityalstudio.com

## §164.310 Physical Safeguards

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| **§164.310(a)(1) Facility Access Controls:** Implement policies and procedures to limit physical access to its electronic information systems and the facility or facilities in which they are housed, while ensuring that properly authorized access is allowed. | | | |
| N/A - A cloud infrastructure environment is in place to restrict access to electronic information systems. | | | |
| **§164.310(a)(2)(i) Contingency Operations [A]:** Establish (and implement as needed) procedures that allow facility access in support of restoration of lost data under the disaster recovery plan and emergency mode operations plan in the event of an emergency. | | | |
| N/A - A cloud infrastructure environment is in place to restrict access to electronic information systems. | | | |
| **§164.310(a)(2)(ii) Facility Security Plan [A]:** Implement policies and procedures to safeguard the facility and the equipment therein from unauthorized physical access, tampering, and theft. | | | |
| N/A - A cloud infrastructure environment is in place to restrict access to electronic information systems. | | | |
| **§164.310(a)(2)(iii) Access Control and Validation Procedures [A]:** Implement procedures to control and validate a person's access to facilities based on their role or function, including visitor control, and control of access to software programs for testing and revision. | | | |
| N/A - A cloud infrastructure environment is in place to restrict access to electronic information systems. | | | |
| **§164.310(a)(2)(iv) Maintenance Records [A]:** Implement policies and procedures to document repairs and modifications to the physical components of a facility which are related to security (for example:  hardware, walls, doors, and locks). | | | |
| N/A - A cloud infrastructure environment is in place to restrict access to electronic information systems. | | | |
| **§164.310(b) Workstation Use [R]:** Implement policies and procedures that specify the proper functions to be performed, the manner in which those functions are to be performed, and the physical attributes of the surroundings of a specific workstation or class of workstation that can access electronic protected health information. | | | |
| N/A - Electronic protected health information is not accessible via Anthropic workstations. | | | |
| **§164.310(c) Workstation Security [R]:** Implement physical safeguards for all workstations that access electronic protected health information, to restrict access to authorized users. | | | |
| N/A - Electronic protected health information is not accessible via Anthropic workstations. | | | |

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| **§164.310(d)(1) Device and Media Controls:** Implement policies and procedures that govern the receipt and removal of hardware and electronic media that contain electronic protected health information into and out of a facility, and the movement of these items within the facility. | | | |
| N/A - Electronic protected health information is not accessible via Anthropic workstations. | | | |
| **§164.310(d)(2)(i) Disposal [R]:** Implement policies and procedures to address the final disposition of electronic protected health information, and / or the hardware or electronic media on which it is stored. | | | |
| N/A - Electronic protected health information is not accessible via Anthropic workstations. | | | |
| **§164.310(d)(2)(ii) Media Re-Use [R]:** Implement procedures for removal of electronic protected health information from electronic media before the media are made available for re-use. | | | |
| N/A - Electronic protected health information is not accessible via Anthropic workstations. | | | |
| **§164.310(d)(2)(iii) Accountability [A]:** Maintain a record of the movements of hardware and electronic media and any person responsible therefore. | | | |
| N/A - Electronic protected health information is not accessible via Anthropic workstations. | | | |
| **§164.310(d)(2)(iv) Data Backup and Storage [A]:** Create a retrievable, exact copy of electronic protected health information, when needed, before movement of equipment. | | | |
| CTL-012 | Daily, a backup job scheduler is configured to perform backups of the production system. | Inquired of the Infrastructure Engineer to verify that a backup job scheduler was configured to perform backups of the production system on a daily basis. | No exceptions noted. |
| | | Inspected the backup configurations to verify that a backup job scheduler was configured to perform backups of the production system on a daily basis. | No exceptions noted. |
| CTL-013 | Backups are encrypted and stored separately from where the primary data source resides. | Inquired of the Security Engineer to verify that backups were encrypted and stored separately from where the primary data source resides. | No exceptions noted. |
| | | Inspected the backup encryption configurations to verify that backups were encrypted and stored separately from where the primary data source resides. | No exceptions noted. |

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asaad@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-014 | The backup system is configured to retain daily backups for 365 days. | Inquired of the HIPAA Security Officer to verify that the backup system was configured to retain daily backups for 365 days. | No exceptions noted. |
| | | Inspected the backup configuration to verify that the backup system was configured to retain daily backups for 365 days. | No exceptions noted. |
| CTL-045 | Backup policies and procedures are documented and available to guide personnel in the backup process. | Inquired of the HIPAA Security Officer to verify that backup policies and procedures were documented and available to guide personnel in the backup process. | No exceptions noted. |
| | | Inspected the Operations Security Policy to verify that backup policies and procedures were documented and available to guide personnel in the backup process. | No exceptions noted. |

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

## §164.312 Technical Safeguards

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| **§164.312(a)(1) Access Control:** Implement technical policies and procedures for electronic information systems that maintain electronic protected health information to allow access only to those persons or software programs that have been granted access rights as specified in §164.308(a)(4). | | | |
| CTL-001 | Access to the application is restricted via a unique username and password. | Inquired of the HIPAA Security Officer to verify that access to the application was restricted via a unique username and password. | No exceptions noted. |
| | | Inspected the application login prompt and password configurations to verify that access to the application was restricted via a unique username and password. | No exceptions noted. |
| CTL-002 | Role-based permissions are used to restrict access to the application administration interface. | Inquired of the HIPAA Security Officer to verify that role-based permissions were used to restrict access to the application administration interface. | No exceptions noted. |
| | | Inspected the assignable access roles and permissions to verify that role-based permissions were used to restrict access to the application administration interface. | No exceptions noted. |
| CTL-024 | Internal user access is provisioned based on a pre-defined role-based access matrix. | Inquired of the HIPAA Security Officer to verify that internal user access was provisioned based on a pre-defined role-based access matrix. | No exceptions noted. |
| | | Inspected the role-based access configurations and role assignment for a recently onboarded user to verify that internal user access was provisioned based on a pre-defined role-based access matrix. | No exceptions noted. |
| CTL-069 | The cloud management console access authentication parameters are configured to require a unique user ID, complex password, and 2FA. | Inquired of the Infrastructure Engineer to verify that the cloud management console access authentication parameters were configured to require a unique user ID, complex password, and 2FA. | No exceptions noted. |
| | | Inspected the authentication configurations to verify that the cloud management console access authentication parameters were configured to require a unique user ID, complex password, and 2FA. | No exceptions noted. |

Downloaded on Fri, 17 Jan 2025 15:56:36 GMT
Downloaded by asadcloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-070 | Administrator access to the firewall system is restricted to personnel commensurate with their job role. | Inquired of the Infrastructure Engineer to verify that administrator access to the firewall system was restricted to personnel commensurate with their job role. | No exceptions noted. |
| | | Inspected the firewall administrator user listing to verify that administrator access to the firewall system was restricted to personnel commensurate with their job role. | No exceptions noted. |
| CTL-089 | Access to audit logs is restricted to personnel commensurate with their job role. | Inquired of the HIPAA Security Officer to verify that access to audit logs was restricted to personnel commensurate with their job role. | No exceptions noted. |
| | | Inspected the Google SecOps access listing to verify that access to audit logs was restricted to personnel commensurate with their job role. | No exceptions noted. |
| CTL-092 | Administrative access to the SIEM tool is restricted to personnel commensurate with their job role. | Inquired of the Detection and Response Security Engineer to verify that administrative access to the SIEM tool was restricted to personnel commensurate with their job role. | No exceptions noted. |
| | | Inspected the Google SecOps user listing to verify that administrative access to the SIEM tool was restricted to personnel commensurate with their job role. | No exceptions noted. |
| CTL-108 | Direct access to the cloud environments is restricted to temporary access packages. Connections are configured to timeout after a predefined threshold. | Inquired of the Infrastructure Engineer to verify that direct access to the cloud environments was restricted to temporary access packages. Connections were configured to timeout after a predefined threshold. | No exceptions noted. |
| | | Inspected the access control and session timeout configurations to verify that direct access to the cloud environments was restricted to temporary access packages. Connections were configured to timeout after a predefined threshold. | No exceptions noted. |

Downloaded on Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by astro@thoughtcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| **§164.312(a)(2)(i) Unique User Identification [R]:** Assign a unique name and / or number for identifying and tracking user identity. | | | |
| CTL-001 | Access to the application is restricted via a unique username and password. | Inquired of the HIPAA Security Officer to verify that access to the application was restricted via a unique username and password. | No exceptions noted. |
| | | Inspected the application login prompt and password configurations to verify that access to the application was restricted via a unique username and password. | No exceptions noted. |
| CTL-002 | Role-based permissions are used to restrict access to the application administration interface. | Inquired of the HIPAA Security Officer to verify that role-based permissions were used to restrict access to the application administration interface. | No exceptions noted. |
| | | Inspected the assignable access roles and permissions to verify that role-based permissions were used to restrict access to the application administration interface. | No exceptions noted. |
| CTL-069 | The cloud management console access authentication parameters are configured to require a unique user ID, complex password, and 2FA. | Inquired of the Infrastructure Engineer to verify that the cloud management console access authentication parameters were configured to require a unique user ID, complex password, and 2FA. | No exceptions noted. |
| | | Inspected the authentication configurations to verify that the cloud management console access authentication parameters were configured to require a unique user ID, complex password, and 2FA. | No exceptions noted. |
| **§164.312(a)(2)(ii) Emergency Access Procedure [R]:** Establish (and implement as needed) procedures for obtaining necessary electronic protected health information during an emergency. | | | |
| CTL-004 | Incident response procedures are maintained and available to guide personnel when responding to security incidents and breaches. | Inquired of the Detection and Response Security Engineer to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches. | No exceptions noted. |

Downloaded on 11 Apr 2025 15:50:36 GMT
Downloaded by asaini@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the incident response plan to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches. | No exceptions noted. |
| CTL-007 | A DR plan is in place and available to guide personnel in the event of an unexpected disruption in operations. | Inquired of the HIPAA Security Officer to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations. | No exceptions noted. |
| | | Inspected the Business Continuity and Disaster Recovery Plan to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations. | No exceptions noted. |
| CTL-008 | Annually, the DR plan is tested and updated. | Inquired of the HIPAA Security Officer to verify that the DR plan was tested and updated on an annual basis. | No exceptions noted. |
| | | Inspected the DR test exercise and post meeting report to verify that the DR plan was tested and updated within the past 12 months. | No exceptions noted. |
| **§164.312(a)(2)(iii) Automatic Logoff [A]:** Implement electronic procedures that terminate an electronic session after a predetermined time of inactivity. | | | |
| N/A - Electronic protected health information is not accessible via Anthropic workstations. | | | |
| **§164.312(a)(2)(iv) Encryption and Decryption [A]:** Implement a mechanism to encrypt and decrypt electronic protected health information. | | | |
| CTL-013 | Backups are encrypted and stored separately from where the primary data source resides. | Inquired of the Security Engineer to verify that backups were encrypted and stored separately from where the primary data source resides. | No exceptions noted. |
| | | Inspected the backup encryption configurations to verify that backups were encrypted and stored separately from where the primary data source resides. | No exceptions noted. |

Downloaded on Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| **§164.312(b) Audit Controls [R]:** Implement hardware, software, and / or procedural mechanisms that record and examine activity in information systems that contain or use electronic protected health information. | | | |
| CTL-004 | Incident response procedures are maintained and available to guide personnel when responding to security incidents and breaches. | Inquired of the Detection and Response Security Engineer to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches. | No exceptions noted. |
| | | Inspected the incident response plan to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches. | No exceptions noted. |
| CTL-010 | The malware software is configured to perform continuous scans and signature updates on servers. | Inquired of the HIPAA Security Officer to verify that the malware software was configured to perform continuous scans and signature updates on servers. | No exceptions noted. |
| | | Inspected the antivirus dashboard and antivirus enabled on servers to verify that the malware software was configured to perform continuous scans and signature updates on servers. | No exceptions noted. |
| CTL-043 | Patch management software is utilized to monitor current patch levels of servers. | Inquired of the Infrastructure Engineer to verify that patch management software was utilized to monitor current patch levels of servers. | No exceptions noted. |
| | | Inspected the patching configurations to verify that patch management software was utilized to monitor current patch levels of servers. | No exceptions noted. |
| CTL-071 | Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded. | Inquired of the Detection and Response Security Engineer to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| | | Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |

Downloaded at Fri, 17 Apr 2026 15:56:36 GMT
Downloaded by asad@hdlcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| **§164.312(c)(1) Integrity:** Implement policies and procedures to protect electronic protected health information from improper alteration or destruction. | | | |
| CTL-010 | The malware software is configured to perform continuous scans and signature updates on servers. | Inquired of the HIPAA Security Officer to verify that the malware software was configured to perform continuous scans and signature updates on servers. | No exceptions noted. |
| | | Inspected the antivirus dashboard and antivirus enabled on servers to verify that the malware software was configured to perform continuous scans and signature updates on servers. | No exceptions noted. |
| CTL-043 | Patch management software is utilized to monitor current patch levels of servers. | Inquired of the Infrastructure Engineer to verify that patch management software was utilized to monitor current patch levels of servers. | No exceptions noted. |
| | | Inspected the patching configurations to verify that patch management software was utilized to monitor current patch levels of servers. | No exceptions noted. |
| CTL-052 | A defined risk methodology is in place to ensure that standards exist for the treatment of risks throughout the environment to an acceptable level. | Inquired of the Detection and Response Security Engineer to verify that a defined risk methodology was in place to ensure that standards exist for the treatment of risks throughout the environment to an acceptable level. | No exceptions noted. |
| | | Inspected the Risk Management Policy to verify that a defined risk methodology was in place to ensure that standards exist for the treatment of risks throughout the environment to an acceptable level. | No exceptions noted. |
| CTL-071 | Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded. | Inquired of the Detection and Response Security Engineer to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| | | Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |

Downloaded on Fri 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| **§164.312(c)(2) Mechanism to Authenticate Electronic Protected Health Information [A]:** Implement electronic mechanisms to corroborate that electronic protected health information has not been altered or destroyed in an unauthorized manner. | | | |
| CTL-010 | The malware software is configured to perform continuous scans and signature updates on servers. | Inquired of the HIPAA Security Officer to verify that the malware software was configured to perform continuous scans and signature updates on servers. | No exceptions noted. |
| | | Inspected the antivirus dashboard and antivirus enabled on servers to verify that the malware software was configured to perform continuous scans and signature updates on servers. | No exceptions noted. |
| CTL-043 | Patch management software is utilized to monitor current patch levels of servers. | Inquired of the Infrastructure Engineer to verify that patch management software was utilized to monitor current patch levels of servers. | No exceptions noted. |
| | | Inspected the patching configurations to verify that patch management software was utilized to monitor current patch levels of servers. | No exceptions noted. |
| CTL-071 | Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded. | Inquired of the Detection and Response Security Engineer to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| | | Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| **§164.312(d) Person or Entity Authentication [R]:** Implement procedures to verify that a person or entity seeking access to electronic protected health information is the one claimed. | | | |
| CTL-002 | Role-based permissions are used to restrict access to the application administration interface. | Inquired of the HIPAA Security Officer to verify that role-based permissions were used to restrict access to the application administration interface. | No exceptions noted. |

Downloaded at Fri, 15 Apr 2025 15:56:36 GMT
Downloaded by academic@controlstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the assignable access roles and permissions to verify that role-based permissions were used to restrict access to the application administration interface. | No exceptions noted. |
| CTL-069 | The cloud management console access authentication parameters are configured to require a unique user ID, complex password, and 2FA. | Inquired of the Infrastructure Engineer to verify that the cloud management console access authentication parameters were configured to require a unique user ID, complex password, and 2FA. | No exceptions noted. |
| | | Inspected the authentication configurations to verify that the cloud management console access authentication parameters were configured to require a unique user ID, complex password, and 2FA. | No exceptions noted. |
| **§164.312(e)(1) Transmission Security:** Implement technical security measures to guard against unauthorized access to electronic protected health information that is being transmitted over an electronic communications network. | | | |
| CTL-043 | Patch management software is utilized to monitor current patch levels of servers. | Inquired of the Infrastructure Engineer to verify that patch management software was utilized to monitor current patch levels of servers. | No exceptions noted. |
| | | Inspected the patching configurations to verify that patch management software was utilized to monitor current patch levels of servers. | No exceptions noted. |
| **§164.312(e)(2)(i) Integrity Controls [A]:** Implement security measures to ensure that electronically transmitted electronic protected health information is not improperly modified without detection until disposed of. | | | |
| CTL-043 | Patch management software is utilized to monitor current patch levels of servers. | Inquired of the Infrastructure Engineer to verify that patch management software was utilized to monitor current patch levels of servers. | No exceptions noted. |
| | | Inspected the patching configurations to verify that patch management software was utilized to monitor current patch levels of servers. | No exceptions noted. |

Downloaded on 11-Apr-2026 15:56:36 GMT
Downloaded by asad@controlstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-071 | Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded. | Inquired of the Detection and Response Security Engineer to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| | | Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded. | No exceptions noted. |
| **§164.312(e)(2)(ii) Encryption [A]:** Implement a mechanism to encrypt electronic protected health information whenever deemed appropriate. | | | |
| CTL-013 | Backups are encrypted and stored separately from where the primary data source resides. | Inquired of the Security Engineer to verify that backups were encrypted and stored separately from where the primary data source resides. | No exceptions noted. |
| | | Inspected the backup encryption configurations to verify that backups were encrypted and stored separately from where the primary data source resides. | No exceptions noted. |

Downloaded on Fri, 14 Mar 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

## §164.314 Organizational Requirements

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| **§164.314(a)(1) Business Associate Contracts or Other Arrangements:** The contract or other arrangement required by §164.308(b)(3) must meet the requirements of paragraph (a)(2)(i), (a)(2)(ii), or (a)(2)(iii) of this section, as applicable. | | | |
| CTL-060 | Annually, a vendor review is performed that includes identifying and assessing the risks associated with third parties. | Inquired of the HIPAA Security Officer to verify that a vendor review was performed on an annual basis that included identifying and assessing the risks associated with third parties. | No exceptions noted. |
| | | Inspected the due diligence records for a sample of active vendors to verify that a vendor review was performed within the past 12 months that included identifying and assessing the risks associated with third parties. | No exceptions noted. |
| CTL-072 | During the vendor onboarding process, vendors that may come in contact with PHI sign BAAs to ensure compliance requirements and responsibilities are communicated. | Inquired of the HIPAA Security Officer to verify that during the vendor onboarding process, vendors that may come in contact with PHI signed BAAs to ensure compliance requirements and responsibilities were communicated. | No exceptions noted. |
| | | No test of the control was performed because the circumstances that warranted the operation of the control did not occur within the past 12 months. | N/A |
| **§164.314(a)(2)(i) Business Associate Contracts [R]:** The contract must provide that the business associate will:<br>(A) Comply with the applicable requirements of this subpart;<br>(B) In accordance with §164.308(b)(2), ensure that any subcontractors that create, receive, maintain, or transmit electronic protected health information on behalf of the business associate agree to comply with the applicable requirements of this subpart by entering into a contract or other arrangement that complies with this section; and<br>(C) Report to the covered entity any security incident of which it becomes aware, including breaches of unsecured protected health information as required by § 164.410. | | | |
| CTL-060 | Annually, a vendor review is performed that includes identifying and assessing the risks associated with third parties. | Inquired of the HIPAA Security Officer to verify that a vendor review was performed on an annual basis that included identifying and assessing the risks associated with third parties. | No exceptions noted. |

Downloaded on Thu, 11 Apr 2025 15:56:26 GMT
Downloaded by ssadeq@controlstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the due diligence records for a sample of active vendors to verify that a vendor review was performed within the past 12 months that included identifying and assessing the risks associated with third parties. | No exceptions noted. |
| CTL-072 | During the vendor onboarding process, vendors that may come in contact with PHI sign BAAs to ensure compliance requirements and responsibilities are communicated. | Inquired of the HIPAA Security Officer to verify that during the vendor onboarding process, vendors that may come in contact with PHI signed BAAs to ensure compliance requirements and responsibilities were communicated. | No exceptions noted. |
| | | No test of the control was performed because the circumstances that warranted the operation of the control did not occur within the past 12 months. | N/A |
| **§164.314(a)(2)(ii) Other Arrangements [R]:** The covered entity is in compliance with paragraph (a)(1) of this section if it has another arrangement in place that meets the requirements of §164.504(e)(3). | | | |
| N/A - The requirements of §164.504(e)(3) do not apply to Anthropic. | | | |
| **§164.314(a)(2)(iii) Business Associate Contracts with Subcontractors [R]:** The requirements of paragraphs (a)(2)(i) and (a)(2)(ii) of this section apply to the contract or other arrangement between a business associate and a subcontractor required by §164.308(b)(4) in the same manner as such requirements apply to contracts or other arrangements between a covered entity and business associate. | | | |
| CTL-022 | The terms of use and privacy policy are available on the company website to provide the terms and conditions concerning the use of the site and to address privacy concerns on data that may be collected through the use of their online products and services. | Inquired of the HIPAA Security Officer to verify that the terms of use and privacy policy were available on the company website to provide the terms and conditions concerning the use of the site and to address privacy concerns on data that may be collected through the use of their online products and services. | No exceptions noted. |
| | | Inspected the Terms of Service and Privacy Policy to verify that the terms of use and privacy policy were available on the company website to provide the terms and conditions concerning the use of the site and to address privacy concerns on data that may be collected through the use of their online products and services. | No exceptions noted. |

Downloaded on 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-060 | Annually, a vendor review is performed that includes identifying and assessing the risks associated with third parties. | Inquired of the HIPAA Security Officer to verify that a vendor review was performed on an annual basis that included identifying and assessing the risks associated with third parties. | No exceptions noted. |
| | | Inspected the due diligence records for a sample of active vendors to verify that a vendor review was performed within the past 12 months that included identifying and assessing the risks associated with third parties. | No exceptions noted. |
| **§164.314(b)(1) Requirements for Group Health Plans:** Except when the only electronic protected health information disclosed to a plan sponsor is disclosed pursuant to §164.504(f)(1)(ii) or (iii), or as authorized under §164.508, a group health plan must ensure that its plan documents provide that the plan sponsor will reasonably and appropriately safeguard electronic protected health information created, received, maintained, or transmitted to or by the plan sponsor on behalf of the group health plan. | | | |
| N/A - Anthropic is not a group health plan provider and therefore this section does not apply. | | | |
| **§164.314(b)(2)(i) Plan Sponsor to Implement Safeguards [R]:** The plan documents of the group health plan must be amended to incorporate provisions to require the plan sponsor to implement administrative, physical, and technical safeguards that reasonably and appropriately protect the confidentiality, integrity, and availability of the electronic protected health information that it creates, receives, maintains, or transmits on behalf of the group health plan. | | | |
| N/A - Anthropic is not a group health plan provider and therefore this section does not apply. | | | |
| **§164.314(b)(2)(ii) Adequate Separation Between Group Health Plan and Plan Sponsor [R]:** The plan documents of the group health plan must be amended to incorporate provisions to require the plan sponsor to ensure that the adequate separation required by §164.504(f)(2)(iii) is supported by reasonable and appropriate security measures. | | | |
| N/A - Anthropic is not a group health plan provider and therefore this section does not apply. | | | |
| **§164.314(b)(2)(iii) Security Measures for Plan Sponsor Agents [R]:** The plan documents of the group health plan must be amended to incorporate provisions to require the plan sponsor to ensure that any agent to whom it provides this information agrees to implement reasonable and appropriate security measures to protect the information. | | | |
| N/A - Anthropic is not a group health plan provider and therefore this section does not apply. | | | |
| **§164.314(b)(2)(iv) Plan Sponsor to Report Security Incidents [R]:** The plan documents of the group health plan must be amended to incorporate provisions to require the plan sponsor to report to the group health plan any security incident of which it becomes aware. | | | |
| N/A - Anthropic is not a group health plan provider and therefore this section does not apply. | | | |

Downloaded by Ali Ali Ali (025-45-5636) GMT
Downloaded by sad@cloudcontrolstudio.com

## §164.316 Policies, Procedures and Documentation Requirements

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| **§164.316(a) Policies and Procedures:** Implement reasonable and appropriate policies and procedures to comply with the standards, implementation specifications, or other requirements of this subpart, taking into account those factors specified in §164.306(b)(2)(i), (ii), (iii), and (iv). This standard is not to be construed to permit or excuse an action that violates any other standard, implementation specification, or other requirements of this subpart. A covered entity or business associate may change its policies and procedures at any time, provided that the changes are documented and are implemented in accordance with this subpart. | | | |
| CTL-004 | Incident response procedures are maintained and available to guide personnel when responding to security incidents and breaches. | Inquired of the Detection and Response Security Engineer to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches. | No exceptions noted. |
| | | Inspected the incident response plan to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches. | No exceptions noted. |
| CTL-007 | A DR plan is in place and available to guide personnel in the event of an unexpected disruption in operations. | Inquired of the HIPAA Security Officer to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations. | No exceptions noted. |
| | | Inspected the Business Continuity and Disaster Recovery Plan to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations. | No exceptions noted. |
| CTL-022 | The terms of use and privacy policy are available on the company website to provide the terms and conditions concerning the use of the site and to address privacy concerns on data that may be collected through the use of their online products and services. | Inquired of the HIPAA Security Officer to verify that the terms of use and privacy policy were available on the company website to provide the terms and conditions concerning the use of the site and to address privacy concerns on data that may be collected through the use of their online products and services. | No exceptions noted. |
| | | Inspected the Terms of Service and Privacy Policy to verify that the terms of use and privacy policy were available on the company website to provide the terms and conditions concerning the use of the site and to address privacy concerns on data that may be collected through the use of their online products and services. | No exceptions noted. |

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asgud@cloudsecurityalliance.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| CTL-033 | Procedures are documented in a new hire checklist to guide personnel during the onboarding process. | Inquired of the HIPAA Security Officer to verify that procedures were documented in a new hire checklist to guide personnel during the onboarding process. | No exceptions noted. |
| | | Inspected the onboarding checklist to verify that procedures were documented in a new hire checklist to guide personnel during the onboarding process. | No exceptions noted. |
| CTL-034 | Procedures are documented in a termination checklist to guide personnel during the off-boarding process. | Inquired of the HIPAA Security Officer to verify that procedures were documented in a termination checklist to guide personnel during the off-boarding process. | No exceptions noted. |
| | | Inspected the offboarding checklist to verify that procedures were documented in a termination checklist to guide personnel during the off-boarding process. | No exceptions noted. |
| CTL-044 | Policies and procedures are documented and available on a shared file storage to guide employees. | Inquired of the HIPAA Security Officer to verify that policies and procedures were documented and available on a shared file storage to guide employees. | No exceptions noted. |
| | | Inspected the policy storage to verify that policies and procedures were documented and available on a shared file storage to guide employees. | No exceptions noted. |
| CTL-046 | Change control policies and procedures are documented, maintained, and available to guide personnel through the change control process. | Inquired of the HIPAA Security Officer to verify that change control policies and procedures were documented, maintained, and available to guide personnel through the change control process. | No exceptions noted. |
| | | Inspected the Operations Security Policy and the Secure Development Policy to verify that change control policies and procedures were documented, maintained, and available to guide personnel through the change control process. | No exceptions noted. |
| CTL-049 | Information security policies and procedures are documented, available to guide personnel, and updated annually. | Inquired of the HIPAA Security Officer to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis. | No exceptions noted. |

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by aaadcbcbbd@mkolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months. | No exceptions noted. |
| CTL-052 | A defined risk methodology is in place to ensure that standards exist for the treatment of risks throughout the environment to an acceptable level. | Inquired of the Detection and Response Security Engineer to verify that a defined risk methodology was in place to ensure that standards exist for the treatment of risks throughout the environment to an acceptable level. | No exceptions noted. |
| | | Inspected the Risk Management Policy to verify that a defined risk methodology was in place to ensure that standards exist for the treatment of risks throughout the environment to an acceptable level. | No exceptions noted. |
| **§164.316(b)(1) Documentation:** (i) Maintain the policies and procedures implemented to comply with this subpart in written (which may be electronic) form; and (ii) If an action, activity or assessment is required by this subpart to be documented, maintain a written (which may be electronic) record of the action, activity, or assessment. | | | |
| CTL-036 | Weekly, Executive Management meets to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | Inquired of the HIPAA Security Officer to verify that executive management met on a weekly basis to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | No exceptions noted. |
| | | Inspected the meeting minutes for a sample of weeks within the past 12 months to verify that executive management met on a weekly basis to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | No exceptions noted. |
| CTL-037 | Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments. | Inquired of the HIPAA Security Officer to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments. | No exceptions noted. |

Downloaded on Fri, 17 Apr 2026 15:56:36 GMT
Downloaded by asad@cloudcomplstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the organization's Executive Risk Council meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments. | No exceptions noted. |
| CTL-044 | Policies and procedures are documented and available on a shared file storage to guide employees. | Inquired of the HIPAA Security Officer to verify that policies and procedures were documented and available on a shared file storage to guide employees. | No exceptions noted. |
| | | Inspected the policy storage to verify that policies and procedures were documented and available on a shared file storage to guide employees. | No exceptions noted. |
| CTL-049 | Information security policies and procedures are documented, available to guide personnel, and updated annually. | Inquired of the HIPAA Security Officer to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis. | No exceptions noted. |
| | | Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months. | No exceptions noted. |
| **§164.316(b)(2)(i) Time Limit of Documentation [R]:** Retain the documentation required by paragraph (b)(1) of this section for 6 years from the date of its creation or the date when it last was in effect, whichever is later. | | | |
| CTL-044 | Policies and procedures are documented and available on a shared file storage to guide employees. | Inquired of the HIPAA Security Officer to verify that policies and procedures were documented and available on a shared file storage to guide employees. | No exceptions noted. |
| | | Inspected the policy storage to verify that policies and procedures were documented and available on a shared file storage to guide employees. | No exceptions noted. |
| CTL-047 | A data classification policy is in place that defines processes and procedures for the protection of information assets. | Inquired of the HIPAA Security Officer to verify that a data classification policy was in place that defines processes and procedures for the protection of information assets. | No exceptions noted. |

Downloaded by asset@audcontrolstudio.com on 2025-15-56:36 GMT

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the Data Management Policy to verify that a data classification policy was in place that defines processes and procedures for the protection of information assets. | No exceptions noted. |
| CTL-048 | Policies and procedures for the retention and destruction of information assets are maintained and available to guide personnel. | Inquired of the HIPAA Security Officer to verify that policies and procedures for the retention and destruction of information assets were maintained and available to guide personnel. | No exceptions noted. |
| | | Inspected the Data Management Policy to verify that policies and procedures for the retention and destruction of information assets were maintained and available to guide personnel. | No exceptions noted. |
| **§164.316(b)(2)(ii) Availability of Documentation [R]:** Make documentation available to those persons responsible for implementing the procedures to which the documentation pertains. | | | |
| CTL-033 | Procedures are documented in a new hire checklist to guide personnel during the onboarding process. | Inquired of the HIPAA Security Officer to verify that procedures were documented in a new hire checklist to guide personnel during the onboarding process. | No exceptions noted. |
| | | Inspected the onboarding checklist to verify that procedures were documented in a new hire checklist to guide personnel during the onboarding process. | No exceptions noted. |
| CTL-034 | Procedures are documented in a termination checklist to guide personnel during the off-boarding process. | Inquired of the HIPAA Security Officer to verify that procedures were documented in a termination checklist to guide personnel during the off-boarding process. | No exceptions noted. |
| | | Inspected the offboarding checklist to verify that procedures were documented in a termination checklist to guide personnel during the off-boarding process. | No exceptions noted. |
| CTL-038 | Organizational charts are used to define the organizational structure of the company and provide reporting lines and relative ranks for positions within departments. | Inquired of the HIPAA Security Officer to verify that organizational charts were used to define the organizational structure of the company and provide reporting lines and relative ranks for positions within departments. | No exceptions noted. |

Downloaded on Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by ctead@protechnolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the organizational charts to verify that organizational charts were used to define the organizational structure of the company and provide reporting lines and relative ranks for positions within departments. | No exceptions noted. |
| CTL-039 | Roles and responsibilities are defined in written job descriptions. | Inquired of the HIPAA Security Officer to verify that roles and responsibilities were defined in written job descriptions. | No exceptions noted. |
| | | Inspected the job descriptions to verify that roles and responsibilities were defined in written job descriptions. | No exceptions noted. |
| CTL-044 | Policies and procedures are documented and available on a shared file storage to guide employees. | Inquired of the HIPAA Security Officer to verify that policies and procedures were documented and available on a shared file storage to guide employees. | No exceptions noted. |
| | | Inspected the policy storage to verify that policies and procedures were documented and available on a shared file storage to guide employees. | No exceptions noted. |
| CTL-049 | Information security policies and procedures are documented, available to guide personnel, and updated annually. | Inquired of the HIPAA Security Officer to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis. | No exceptions noted. |
| | | Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months. | No exceptions noted. |
| **§164.316(b)(2)(iii) Updates of Documentation [R]:** Review documentation periodically, and update as needed, in response to environmental or operational changes affecting the security of the electronic protected health information. | | | |
| CTL-003 | Annually, a risk assessment is performed by management and includes identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. | Inquired of the HIPAA Security Officer to verify that a risk assessment was performed by management on an annual basis and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. | No exceptions noted. |

Downloaded on Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@claudocontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the risk registry to verify that a risk assessment was performed by management within the past 12 months and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. | No exceptions noted. |
| CTL-033 | Procedures are documented in a new hire checklist to guide personnel during the onboarding process. | Inquired of the HIPAA Security Officer to verify that procedures were documented in a new hire checklist to guide personnel during the onboarding process. | No exceptions noted. |
| | | Inspected the onboarding checklist to verify that procedures were documented in a new hire checklist to guide personnel during the onboarding process. | No exceptions noted. |
| CTL-034 | Procedures are documented in a termination checklist to guide personnel during the off-boarding process. | Inquired of the HIPAA Security Officer to verify that procedures were documented in a termination checklist to guide personnel during the off-boarding process. | No exceptions noted. |
| | | Inspected the offboarding checklist to verify that procedures were documented in a termination checklist to guide personnel during the off-boarding process. | No exceptions noted. |
| CTL-036 | Weekly, Executive Management meets to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | Inquired of the HIPAA Security Officer to verify that executive management met on a weekly basis to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | No exceptions noted. |
| | | Inspected the meeting minutes for a sample of weeks within the past 12 months to verify that executive management met on a weekly basis to discuss business objectives, changes in relevant regulations and statutory requirements, and establish company direction. | No exceptions noted. |
| CTL-037 | Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments. | Inquired of the HIPAA Security Officer to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments. | No exceptions noted. |

Downloaded on Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asaf@thecontrolstudio.com

| # | Control Identified / In Place | Testing Steps | Results of Testing |
|---|---|---|---|
| | | Inspected the organization's Executive Risk Council meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments. | No exceptions noted. |
| CTL-044 | Policies and procedures are documented and available on a shared file storage to guide employees. | Inquired of the HIPAA Security Officer to verify that policies and procedures were documented and available on a shared file storage to guide employees. | No exceptions noted. |
| | | Inspected the policy storage to verify that policies and procedures were documented and available on a shared file storage to guide employees. | No exceptions noted. |

Downloaded on Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

## SECTION 7:

## INFORMATION PROVIDED BY THE SERVICE ORGANIZATION THAT IS NOT COVERED BY THE SERVICE AUDITOR'S REPORT

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

## Management's Responses to the Testing Exceptions

| Control # | Control Activities Specified by the Service Organization | Test Applied by the Service Auditor | Testing Results | Management's Response |
|---|---|---|---|---|
| CTL-025 | Upon hire, users are required to complete security awareness training. | Inspected the completed security awareness training records for a sample of users onboarded within the past 12 months to verify that upon hire, users were required to complete security awareness training. | Exceptions noted.<br><br>360 Advanced noted that three out of 40 sampled users onboarded during the examination period did not complete security awareness training. | Anthropic acknowledges and agrees with this finding. The three sampled users did not complete the training within the specified time period. When the process for assuring completion of this training was migrated from in-person to online, additional procedures to verify timely completion were not adequately implemented. Even though online training was not completed, all new hires received in-person security awareness training as part of their onboarding sessions.<br><br>Anthropic has identified a security training specialist. This specialist has deployed a new learning management and policy attestation platform to assure accurate enrollment and on-time delivery of all security training materials, to escalate training lapses to responsible managers, and to report conformance status to executive leadership. |
| CTL-026 | Upon hire, employees are required to sign acceptance of the Information Security Policy. | Inspected the information security policy acknowledgements for a sample of users onboarded within the past 12 months to verify that upon hire, employees were required to sign acceptance of the information security policy. | Exceptions noted.<br><br>360 Advanced noted that 13 out of 40 sampled users onboarded during the examination period did not acknowledge the information security policy. | Anthropic acknowledges and agrees with this finding. Manual procedures and automated reminders were insufficient to assure that new personnel completed this activity. While execution of the acknowledgement was insufficient, Anthropic confirms that all users, inclusive of the mentioned 13, had access to all policies and procedures and such policies and procedures are covered as a part of all user onboarding sessions.<br><br>Anthropic has identified a security training specialist. This specialist has deployed a new learning management and policy attestation platform to assure accurate enrollment and on-time delivery of all security training materials, to escalate training lapses to responsible managers, and to report conformance status to executive leadership. |

Downloaded by Eric Lu Apr 2025 Downloaded by asad@cloudconformist.com

| Control # | Control Activities Specified by the Service Organization | Test Applied by the Service Auditor | Testing Results | Management's Response |
|---|---|---|---|---|
| CTL-029 | Annually, users are required to complete security awareness training. | Inspected the completed security awareness training records for a sample of tenured employees to verify that employees were required to complete security awareness training within the past 12 months. | Exceptions noted.<br><br>360 Advanced noted that 11 out of 22 sampled tenured users did not complete security awareness training within the past 12 months | Anthropic acknowledges and agrees with this finding. The 11 sampled users did not complete the training within the specified time period. Anthropic identified a defect in the training vendor's implementation of their enrollment algorithm.<br><br>Anthropic has identified a security training specialist. This specialist has deployed a new learning management and policy attestation platform to assure accurate enrollment and on-time delivery of all security training materials, to escalate training lapses to responsible managers, and to report conformance status to executive leadership.<br><br>Compensating controls enforcing patching levels on personnel workstations, password requirements, device security settings, and security event monitoring remained effective.<br><br>Additionally, Anthropic maintains a real-time feed of alerts to its personnel, warning them of detected phishing, vishing, and other social engineering attacks as they become known to the security organization. |

Downloaded at Fri, 11 Apr 2025 15:56:36 GMT
Downloaded by asad@cloudcontrolstudio.com

| Control # | Control Activities Specified by the Service Organization | Test Applied by the Service Auditor | Testing Results | Management's Response |
|---|---|---|---|---|
| CTL-031 | Accounts assigned to terminated non-privileged users are disabled or deleted upon termination. | Inspected the offboarding records and account statuses for a sample of non-privileged users offboarded during the examination period to verify that accounts assigned to terminated non-privileged users were disabled or deleted upon termination. | Exceptions noted.<br><br>360 Advanced noted that three out of five non-privileged users' access was not disabled or deleted upon termination. | Anthropic acknowledges and agrees with this finding. In all cases, access for these non-privileged personnel was removed well after the indicated termination date. However, the termination date was set to a date in the past by the responsible HRIS administrator to align with the date that invoiced services ceased, as these are contingent workers. This made it impossible for account termination to occur in a timely manner. Compensating controls assuring contractual protections, device health, and activity monitoring remained effective.<br><br>The responsible HRIS administrators have been re-educated that backdated end dates are not appropriate. Additionally, pre-set termination dates for contingent workers are now executed automatically. |

Downloaded by asad@cloudcontrolstudio.com at Fri, 11 Apr 2025 15:56:36 GMT